



File No.: EXP202305587

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

Content

BACKGROUND.....	3
FIRST:.....	3
SECOND:.....	3
THIRD:.....	4
FOURTH:.....	4
FIFTH:.....	4
SIXTH:.....	4
SEVENTH:.....	5
EIGHTH:.....	5
Regulatory framework.....	5
System architecture and database. GEA application.....	7
Regarding the chronology of events. Actions taken to minimize adverse effects and measures adopted for final resolution.....	10
Regarding the causes that made the breach possible.....	13
Regarding the data processing agreement.....	18
Regarding security measures.....	18
Regarding communication to the affected parties.....	25
Information on the recurrence of these events and the number of analogous events that occurred over time.....	25
PROVEN FACTS.....	28
FIRST: First notification of personal data breach.....	28
SECOND: Circumstances of the attack.....	31
THIRD: On the GEA application of I-DE.....	35
FOURTH: On the system architecture and database. Access from applications.....	35
FIFTH: Causes that made the breach possible.....	37
C/ Jorge Juan, 6	
www.aepd.es	
28001 – Madrid	
sedeagpd.gob.es	
2/99	
SIXTH: Security measures established in the Database.....	38
SEVENTH: Immediate measures following the breach.....	38
EIGHTH: IBERDROLA as the data processor regarding IBERCLI and CURENERGÍA.....	39
NINTH: Risk analysis of the processing affected by the personal data breach.....	41
TENTH: Number of affected individuals and type of affected data.....	42
LEGAL GROUNDS.....	42
Competence.....	42
Preliminary issues.....	42
Regarding the request for accumulation and the suspension of the deadline to submit allegations.....	43
Response to the allegations regarding the Initiation Agreement.....	45
FIRST: ON THE ACCUMULATION OF THE PROCEEDINGS.....	45
SECOND: ON THE SPECIAL CIRCUMSTANCES OCCURRED IN RELATION TO THE PROCESSING OF THIS FILE AND THE VIOLATION OF THE PRINCIPLES OF GOOD FAITH,	

LEGITIMATE EXPECTATION, AND LEGAL SECURITY.....	45
THIRD: ON THE ADDITIONAL IMPACT ON THE PRINCIPLES OF SANCTIONING LAW DERIVED FROM THE INTERPRETATION MADE BY THE AEPD.....	51
FOURTH: ON THE ALLEGED VIOLATION BY IBERDROLA OF ARTICLE 32 OF THE GDPR.....	60
FIFTH: ON THE ALLEGED VIOLATION OF THE PRINCIPLE OF SECURITY.....	65
SIXTH: ON THE VIOLATION OF THE PRINCIPLE OF PROPORTIONALITY TO THE DETRIMENT OF IBERDROLA'S RIGHTS.....	66
Response to the allegations regarding the Proposed Resolution.....	69
FIRST: On the defenselessness generated for IBERDROLA as a consequence of the failure to agree on the accumulation of proceedings EXP202305587 and EXP202205206.....	70
SECOND: Regarding the prior acts of the AEPD and the violation of the principles of good faith, legitimate expectation, and legal security.....	70
THIRD: On the arguments presented by the Proposed Resolution to consider that there is no bis in idem.....	76
C/ Jorge Juan, 6	
www.aepd.es	
28001 – Madrid	
sedeagpd.gob.es	
3/99	
FOURTH: Regarding the application of the principles of sanctioning law to the activity of the AEPD and the concurrence of a medial contest.....	79
FIFTH: Regarding the non-existence of a violation by I-DE of Article 32 of the GDPR.....	84
SIXTH: Regarding the non-existence of a violation of the principle of confidentiality and integrity.....	95
SEVENTH: Regarding the violation of the principle of proportionality to the detriment of the rights of IBERDROLA.....	99
Integrity and confidentiality.....	105
Classification of the infringement of Article 5.1.f) of the GDPR.....	107
Sanction for the infringement of Article 5.1.f) of the GDPR.....	108
Article 32 of the GDPR.....	110
Classification of the infringement of Article 32 of the GDPR.....	113
Sanction for the infringement of Article 32 of the GDPR.....	114

BACKGROUND

FIRST:

On March 18, 2022, the Division of Technological Innovation of this Spanish Agency for Data Protection (hereinafter AEPD or the Agency) was notified of a security breach of personal data reported by I-DE REDES ELÉCTRICAS INTELIGENTES, S.A.U. with NIF A95075578 (hereinafter, I-DE) as the data controller, in which it informs this Agency of the following:

On the afternoon of March 15, 2022, an attack against the management website for connections (GEA) of I-DE was detected. (...). At this moment, no impact on personal data is identified. The next day, March 16, a brute force attack directed against the same target (GEA) as the incident the previous day is detected. Measures are taken to repel it. On March 17, GEA is reopened, the activity log is analyzed, and it is concluded that there has been an extraction of personal data. It is indicated that the number of affected individuals is 4.5 million customers of this company.

SECOND:

On March 29, 2022, I-DE submitted a new notification expanding the information regarding the security breach reported on the 18th of the same month, indicating that, after a forensic analysis of the incident,

the number of its customers whose data has been affected is 1.35 million and that it is also likely that there are affected data from customers of other companies in the Iberdrola group, as the attacker could potentially have surpassed the security conditions of the information exclusive to I-DE, accessing information ranges of other companies, which has already been communicated to the Company's Systems management for a detailed analysis of other impacts on other companies or businesses of the Iberdrola group.

They also indicate that the exact date of the start of the breach is March 7, 2022, and inform that the breach has not yet been communicated to the affected individuals and that, at the latest, they will be informed by March 31, 2022.

Along with the notification, the following is provided:

- Report "Cyber Incident GEA. Incident Description and Actions," which describes the attack suffered and also includes the text of the communication that will be sent to the affected individuals.

THIRD:

On March 29, 2022, CURENERGIA COMERCIALIZADOR DE ULTIMO RECURSO SA, with N.I.F. A95554630 (hereinafter CURENERGÍA) submitted a notification of a security breach, indicating that it became aware on March 28, 2022, that it was affected by the security breach suffered by I-DE, indicating the violation of the confidentiality of personal data of 1,550,000 of its customers, whom it has not yet informed but will do so by March 31, 2022, at the latest.

FOURTH:

On March 29, 2022, IBERDROLA CLIENTES, S.A., with N.I.F. A95758389 (hereinafter IBERCLI) submitted a notification of a security breach, indicating that it became aware on March 28, 2022, that it was affected by the security breach suffered by I-DE, indicating the violation of the confidentiality of personal data of 85,000 of its customers, whom it has not yet informed but will do so by March 31, 2022, at the latest.

FIFTH:

Since April 2, 2022, claims have been submitted to this Agency by customers affected by the security incident, which have been progressively admitted for processing since May 9, 2022.

SIXTH:

On April 6, 2022, IBERCLI submitted an extension of the breach notification in which it informs that the individuals affected by it are 1,515,000 and that they were informed of it on March 31, 2022, through communication directed personally to each affected individual (postal, email, SMS, or similar).

Along with the notification, the following is provided:

- Report "Cyberattack Incident 28/03/2022. Incident Description and Actions"
- Annex Communication to Interested Parties

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/99

SEVENTH:

On April 6, 2022, CURENERGÍA submitted an extension of the breach notification in which it informs that the affected individuals number 92,550 and that they were informed of the breach on March 31, 2022, through communication directed personally to each affected individual (postal, email, SMS, or similar).

Along with the notification, the following documents are provided:

- Report "Cyberattack Incident 28/03/2022. Incident Description and Actions"
- Annex Communication to Interested Parties

EIGHTH:

The General Subdirectorate of Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection

Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points:

During the current actions, the following entities have been investigated:

- I-DE REDES ELECTRICAS INTELIGENTES S.A. with NIF A95075578 (hereinafter, I-DE)
- IBERDROLA S.A. with NIF A48010615 (hereinafter IBERDROLA)
- IBERDROLA CLIENTES S.A.U. with NIF A95758389 (hereinafter, IBERCLI)
- CURENERGIA COMERCIALIZADOR DE ULTIMO RECURSO S.A. with NIF A95554630 (hereinafter, CURENERGÍA)

Regulatory Framework

- The regulatory framework of the electricity sector, Law 54/1997, of November 27, on the Electricity Sector, imposes an obligation of total separation between regulated activities, such as distribution, and liberalized activities, such as commercialization.

- The right of consumers of electrical energy to access and connect to the electricity transport and distribution networks in Spanish territory is specifically included in Law 24/2013, of December 26, on the Electricity Sector.

The distribution companies and the commercialization companies are two distinct entities within the Electricity Sector. In this sense, Law 24/2013, of December 26, on the Electricity Sector defines them as different subjects.

- According to the regulation of the electricity sector, the consumer, in order to receive electrical energy at their home, needs to be the holder of two differentiated contracts related to their supply point (CUPS):

☐ On one hand, the energy purchase contract, “supply contract,” which is signed between a consumer and an electricity commercialization company.

Although it is also possible for the consumer to purchase electricity directly in the market, without the need for a commercialization company, this is not typical for individual consumers but rather for large electricity-consuming companies, as indicated by I-DE, IBERCLI, and CURENERGÍA in their response.

☐ On the other hand, the network access or distribution or transport contract, “ATR contract,” which the consumer signs with the intermediation as a representative of the commercialization company with which they have contracted the purchase of electrical energy.

Although it can also be signed directly with the network owner, this is not typical for individual consumers but rather for large electricity-consuming companies, as indicated by I-DE, IBERCLI, and CURENERGÍA in their response.

- When a customer wishes to contract electricity at a supply point or make any contractual modification, that customer approaches a commercialization company, which, on behalf of the customer and as their representative, contracts the ATR contract, the network access contract.

Any contractual modification requested by a commercialization company from a distributor is carried out through digital XML requests, complying with the exchange formats between agents established by the National Commission of Markets and Competition (CNMC), by virtue of the Resolution of December 20, 2016, which approves the formats of the information exchange files between electricity and natural gas distributors and marketers, and the Resolution of December 17, 2019, which approves new formats of the information exchange files between distributors and marketers and modifies the Resolution of December 20, 2016.

Taking the above into account:

- I-DE, the electricity distributor of the Iberdrola group, states that it can only access the data of its customers, that is, the users of the electricity service whose supply point is within the network managed by it as a distributor, and not those managed by other distribution companies.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/99

In relation to the users of its network, it knows the data of the marketer of each consumer as a consequence of the signing with the same (or with the marketer as the representative of the consumer) of the ATR contract.

-

I-DE indicates that it would not have the capacity to know any type of information related to those who, being clients of IBERCLI or CURENERGIA, marketers of electricity from the Iberdrola group in the free market and regulated market, respectively, are not clients of this distributor.

System architecture and database. GEA Application

(...)

(...):

-

(...):

(...)

-

(...).

(...)

(...):

-

(...).

(...).

-

(...).

(...).

(...).

(...).

(...).

IBERDROLA indicates that the verification audit of the logical separation of access to information by I-DE is based on what is established in the regulatory framework of the electricity sector, which imposes an obligation of total separation between regulated activities, such as distribution, and liberalized activities, such as marketing, so that distribution companies must demonstrate the aforementioned separation.

I-DE reports that, annually, it issues a report that is presented to the Ministry for Ecological Transition and the Demographic Challenge (MITERD) and the National Commission on Markets and Competition (CNMC) to account for compliance with the obligations regarding the separation of activities by the companies of the group formed by Iberdrola España and the companies in which it has stakes with regulated activities, namely, the company I-DE REDES ELÉCTRICAS INTELIGENTES, S.A.U., Article 12.2 b) of the Electricity Sector Law and Article 14 of the Code of Separation of Activities of the Companies of the Iberdrola España Group with Regulated Activities ("CSA") available on the Iberdrola España website, during the fiscal year.

(...).

(...):

"(...)

Scope of work

(...)

(...).

Procedures performed

(...):

-

(...)

-

(...)

□

(...)

☐

(...)

Conclusions

(...).

(...).

(...).”

Regarding the chronology of the events. Actions taken to minimize adverse effects and measures adopted for their final resolution.

I-D states the following:

-

On March 15, in the afternoon, an attack was detected against the management website of I-DE, (GEA), with the sequence of events being as follows:

☐

(...).

☐

(...).

☐

(...).

☐

(...).

☐

(...).

☐

(...).

-

On March 16, 2022, in the morning, there was a general slowdown in access to several websites of the Iberdrola group.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/99

☐

(...).

☐

(...).

☐

(...).

☐

(...).

☐

(...).

☐

(...).

☐

(...).

-

From March 17, 2022:

☐

(...).

☐

From the 17th, no suspicious traffic or impact was observed in any of the internet service systems of

the Iberdrola group.

☐

From the analysis of the activity log of the GEA application in the last days, it is concluded as of March 17 that there has been an exfiltration, between March 7 and 15, 2022, of approximately 4.5 million affected individuals (natural persons).

☐

(...).

☐

On March 28, 2022, the Systems Directorate informs IBERCLI and CURENERGIA of the existence of a security incident in the systems of I-DE that may have affected information related to the clients of these companies and includes information regarding the internal client codes of the affected individuals, so that the companies can verify whether data corresponding to their clients may have been compromised. After analyzing the information, IBERCLI and CURENERGIA verify that the security breach has affected personal data of clients of said companies.

☐

(...).

-

Furthermore, I-DE states and certifies that since it became aware of the incident, the necessary actions were implemented to, in coordination with the affected organizations, comply with the established internal protocols and applicable legislation, which include the following actions:

☐

Communication to INCIBE-CERT, the National Cybersecurity Institute in Spain, as the reference cybersecurity incident response team for Iberdrola.

☐

Communication to the Cyber Coordination Office, under RDL 12/2018 on the security of networks and information systems, which refers the cybersecurity incident to the National Police for investigation.

☐

Communication to the National Center for the Protection of Critical Infrastructures under Law 08/2011 on the protection of Critical Infrastructures.

☐

Filing a complaint with the National Police (Central Cybercrime Unit) and the document submitted by I-DE along with it.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/99

☐

Notification of the security breach to the AEPD and to the affected individuals.

-

In summary, the monitoring systems allowed for the detection of an anomalous volume of traffic, a more detailed analysis activity was initiated, and the immediate measures that were adopted were:

☐

(...).

☐

(...).

☐

(...).

☐

(...).

☐

(...).

☐

(...).

☐

(...).

- IBERCLI and CURENERGIA state that the cessation of the incident occurred even before they became aware that it had affected personal data related to their clients, with this cessation being a consequence of the additional security measures implemented by the Systems Directorate (of IBERDROLA) in the GEA application, aimed at preventing information from the Database related to clients of other entities in the Group from being exfiltrated through access to it by introducing a random code.

Regarding the causes that made the breach possible

- (...).

(...).

(...):

(...).

(...).

(...):

(...)

(...):

☐

(...)

(...)

☐

(...)

(...)

or

(...)

☐

(...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/99

(...)

(...)

-

(...)

Regarding the affected data

-

The exfiltrated customer data (...):

☐

(...)

-

(...):

(...)

-

(...):

(...).

-

(...).

-

(...).

(...)

-

(...).

-

(...).

On March 28, 2022, the Systems Directorate informs IBERCLI and CURENERGIA of the existence of a security incident in the I-DE systems that may have affected the information related to the customers of these companies and includes information regarding the internal customer codes of the affected parties, so that the companies can verify whether data corresponding to their customers may have been compromised.

IBERCLI and CURENERGÍA verify that the security breach has affected personal data of 1,515,000 and 92,550 customers, respectively.

Regarding the data processing agreement

-

The Framework Agreement on Personal Data Protection of the Iberdrola Group is provided, detailing the scope of the services provided to the Group companies by IBERDROLA. This agreement has been updated in its Annex II, with such update pending formalization.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/99

Additionally, the Acceptance Declaration of Iberdrola España S.A.U. regarding its adherence to the Framework Agreement on Personal Data Protection of the Iberdrola Group is provided, with the aforementioned entity acting, as indicated in the second clause, in its own name and right and on behalf of the companies belonging to its corporate group over which it holds direct or indirect control, among which are I-DE, IBERCLI, and CURENERGIA.

-

IBERCLI and CURENERGIA provide a copy of the record of the activities of personal data processing corresponding to the treatments affected by the breach:

☐

(...).

☐

(...).

-

IBERDROLA provides a copy of the records of the activities of processing corresponding to the treatments "Support and Maintenance of IT Infrastructures" and "Application Development (SWF)," which it carries out in its capacity as data processor, regarding various treatments of the Group companies, including those affected by the security breach.

Regarding security measures

Regarding the risk analysis conducted on the processing activity that suffered the security breach prior to the breach occurring:

-

IBERDROLA states in its response that the Iberdrola Group has adopted a risk analysis methodology for personal data processing that is implemented automatically in the corporate activity registration tool itself, so that the risk level of the processing is determined in the registration process itself.

-

In the case of the treatments for which IBERDROLA acts as the data processor, it indicates that the methodology involves conducting a risk analysis concerning each of the treatments for which IBERDROLA holds such status, so that this analysis is developed by the entity responsible for the processing in collaboration with IBERDROLA.

-

For this reason, the result of the risk analysis related to the specific treatments (...) is incorporated into the Activity Records of I-DE and those of IBERCLI and CURENERGIA, with its results having been communicated to IBERDROLA.

(...).

- Security measures implemented prior to the breach in the data treatments where it occurred:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/99

I-DE, IBERCLI, and CURENERGIA indicate in their responses that prior to the incident, the following security measures common to the IT infrastructure of the Iberdrola Group were implemented:

-

(...).

-

(...).

-

(...).

-

(...).

-

(...).

-

(...).

-

(...).

-

(...).

Additionally, like IBERDROLA, they also describe the specific security measures of the GEA system:

(...):

☐

(...)

☐

(...).

(...)

(...):

-

(...).

(...):

-

(...).

- Reason why the implemented security measures did not prevent the incident:

(...):

-

(...).

-

(...)

-

(...)

-

(...)

-

(...)

-

(...)

-

(...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/99

-

(...).

-

(...).

Measures adopted to avoid, as much as possible, incidents like the one that occurred

-

(...)

(...)

Regarding the communication to the affected parties

On March 28, 2022, the Systems Directorate of IBERDROLA informs IBERCLI and CURENERGÍA of the existence of a security incident in the I-DE systems that may have affected the information related to the customers of these companies and includes information regarding the internal customer codes of the affected parties, so that the companies can verify whether data corresponding to their customers may have been compromised.

IBERCLI and CURENERGÍA report that after analyzing the information by their respective systems teams, they verify that the security breach has affected personal data of 1,515,000 and 92,550 customers, respectively.

Furthermore, they decide to notify the affected parties of the security breach. The notification to the affected parties was carried out between March 31 and April 1, 2022, to customers for whom an email address was available, through the mass sending of electronic communications; and by postal mail to the remaining customers on April 4 and 5, 2022.

-

The three companies provide the model of communication sent to the affected parties and it is verified that it complies with the specifications in Article 34 of the GDPR.

Information on the recurrence of these events and the number of analogous events that have occurred over time.

IBERDROLA states that aside from the security incident subject to this procedure, no other incident of a similar nature has occurred.

NINTH: The entity IBERDROLA is a large company with a turnover of ***AMOUNT.1 euros in 2021 and ***AMOUNT.2 euros in 2022, according to the report from the entity Axesor.

TENTH: On May 8, 2023, the Director of the Spanish Data Protection Agency agreed to initiate sanctioning proceedings against the respondent, in accordance with the provisions of Articles 63 and 64 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), for the alleged infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified under Article 83.5 of the GDPR and Article 83.4 of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/99

The aforementioned initiation agreement is in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP).

ELEVENTH: On May 24, 2023, IBERDROLA submitted a written request for the accumulation of the present file with EXP202205206, as well as the suspension of the deadline for the submission of allegations until this request is resolved, stating the following:

IBERDROLA understands that the facts that serve as the basis for the exercise of the sanctioning power that the Agency seeks to exercise are or have a single basis that affects the two sanctioning files that have been opened as differentiated, which is why it requests the accumulation of both sanctioning procedures, understanding that there is a necessary connectivity between them, that is, it is the same situation that may result in the responsibility of both. IBERDROLA therefore understands that the terms of such responsibility, total, partial, as an author, as a collaborator, or any other that may arise from the criminal references can only be appreciated if the procedure is analyzed as a whole. IBERDROLA argues that the lack of accumulation in this case could imply a double imputation to two entities of the same facts, which, moreover, belong to the same business group, specifically the Iberdrola group of which IBERDROLA is the parent company.

If both files are not accumulated, IBERDROLA states that it would prevent clarifying the degree of responsibility of each of them, as the facts would be analyzed separately and without assessing the alleged simultaneous action, in terms of responsibility, of the two entities against which both procedures are directed. In this way, a double imputation of the same facts to both entities could be occurring without assessing whether it is shared or whether the separate sanctioning reproach against both should not be subject to reduction as a consequence of that alleged concurrence of responsibility. This limits, in the terms established in the constitutional jurisprudence that is reproduced below, the right to defense of IBERDROLA, as it cannot analyze the concurrent circumstances in the case in a unified manner due to the fragmentation caused by the opening of two differentiated procedures.

IBERDROLA understands that the prerequisites established in Article 57 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP) that justify the accumulation of the procedures, as well as the individualization of the relevance of its application to the present case, are met:

A) Existence of "intimate connection" or "substantial identity".

IBERDROLA points out that, in the present case, on March 18, 2022, a breach of personal data security occurred, initially reported by I-DE. It is this same security breach that determines the opening of the present

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/99

proceeding in which responsibility is attributed to IBERDROLA, as well as that of the proceeding which is intended to be accumulated with the present one, opened to clarify the responsibility of I-DE.

IBERDROLA indicates that the connectivity, in this case, derives from the fact that it concerns the attribution of responsibility to two legal entities, but for the same fact: it is the Agency itself that makes it clear that it is a single security breach and that the subjective responsibilities of IBERDROLA, in the present proceeding, and of I-DE in the proceeding whose accumulation is requested, will be based on the same.

Therefore, IBERDROLA concludes that, given the existence of unique facts for which responsibility is attributed to both it and I-DE, it is evident that a joint assessment of the same is necessary to determine whether there is joint or separate responsibility of both entities, as well as whether the responsibility would be under different titles in each case.

B) That the same body is responsible for the processing and resolution of the proceeding.

IBERDROLA points out that, along with the previous requirement, the LPACAP imposes respect for the general principle of competence of the body that must issue the resolution, a requirement that is met in the present case, since the Law assigns the competence for the processing of both proceedings to a single sanctioning body, so that with the accumulation, that competence is neither lost nor blurred as a result of the potential existence of different instructing bodies.

In IBERDROLA's opinion, the essential effect of the accumulation of files is that all issues to be resolved must be examined in a single proceeding and decided in a single final act that jointly assesses the responsibilities of all those involved.

IBERDROLA notes that the scheme just analyzed has, without a doubt, special characteristics in the sanctioning field due to its own structure and the value judgment that it entails.

It brings up several rulings from the Constitutional Court to highlight that the main principles and constitutional guarantees of criminal law and criminal proceedings must be observed, with certain nuances, in the sanctioning administrative procedure, such as the right to be informed of the accusation (SSTC 31/1986, 190/1987, 29/1989) and to use relevant means of evidence for the defense (SSTC 2/1987, 190/1987, and 212/1990), as well as the right to the presumption of innocence (SSTC 13/1982, 36 and 37/1985, 42/1989, 76/1990, and 138/1990), all fundamental rights that have been incorporated by the legislator into the regulatory framework of the common administrative procedure.

IBERDROLA understands that the fragmentation of the procedure into two separate proceedings substantially affects the determination and verification of the relevant facts therein, as well as the delimitation of the potential responsibilities that may correspond to the entities to which the proceedings whose accumulation is requested are directed.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/99

IBERDROLA concludes that the accumulation is a requirement for proper instruction and for the guarantee of the right to defense, and that the separate processing of two sanctioning files against two different legal entities for the same facts is detrimental to their interests.

IBERDROLA understands that the lack of accumulation in the present case could imply a double imputation to IBERDROLA and I-DE, as mentioned, for the same facts, without the accumulation allowing for clarification of the degree of responsibility of each of them, since the facts would be analyzed separately and without assessing the alleged simultaneous actions, in terms of responsibility, of the two entities against which both procedures are directed.

It understands that maintaining the separation of the procedures implies, in procedural terms, a fragmentation of the cause that conditions the instructive and proposal actions because different instructions, evaluations, and potentially different evidence appear, and therefore, criteria that can also be differentiated.

For all the above reasons, IBERDROLA requests the accumulation of the two aforementioned files and that the suspension of the deadline for the formalization of allegations be expressly requested until the incident of accumulation raised in this document is resolved.

Furthermore, IBERDROLA understands that, considering the nature of what is requested and the impact on the instruction of the files in question and, ultimately, on the right to defense of the interested parties in both procedures, as it substantially affects the content of the allegations that IBERDROLA could make in the event that the aforementioned accumulation is agreed upon, with the consequent reduction of its right to effective judicial protection in its modality of using the necessary means of evidence for the adequate defense of its rights, we expressly request the suspension of the deadline for the formalization of allegations so that they can be made according to the instructive criteria that we are requesting.

Therefore, IBERDROLA requests the suspension of the deadline for the formalization of allegations until the incident of accumulation raised in this document is resolved.

TWELFTH: On January 30, 2024, IBERDROLA submitted a written statement of allegations to the Proposal for Resolution of the sanctioning procedure.

THIRTEENTH

From the actions carried out in the present procedure and from the documentation in the file, the following have been accredited:

PROVEN FACTS

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

18/99

FIRST: First notification of personal data breach

1.- Notifications of personal data breach made by I-DE:

A) On March 18, 2022, a security breach of personal data was notified to the Division of Technological Innovation of this Spanish Agency for Data Protection (hereinafter AEPD or the Agency) by I-DE REDES ELÉCTRICAS INTELIGENTES, S.A.U. with NIF A95075578 (hereinafter, I-DE) as the data controller, in which it informs this Agency of the following:

(...).

It is indicated that the number of affected individuals is 4.5 million customers of this company.

A) On March 29, 2022 (Registration Number: REGAGE22e00010072289), I-DE submitted a new notification expanding the information regarding the notified personal data breach, through the submission of the report "Cyber Incident GEA. Incident description and actions." dated March 28, 2022, according to which:

"I-DE, within the provision of services to its customers, offers a web application called Management of Files and Connections (GEA): ***URL.1

This service allows customers or their representatives (installers) to carry out the necessary procedures for the process of connecting to the network. During the sessions of the application, there is an exchange of customer data information that is subject to the security filters of the application, so that each customer (or delegated representative) can only access the information corresponding to the security and access profiles provided.

It indicates that the number of affected customers of I-DE is 1,350,000.

It indicates the start date of the breach as March 7, 2022.

It informs that the breach has not yet been communicated to the affected individuals and that, at the latest, they will be informed by March 31, 2022.

Furthermore, in the aforementioned report "Cyber Incident GEA. Incident description and actions," it is indicated:

"6. Analysis of the extracted information

Based on the information from the forensic analysis, I-DE has carried out an analysis of the records of potentially extracted information.

From the file sent to I-DE with the customers affected by the security breach that contains 4.5 million records of individuals, it has been verified that approximately 1.3 million are customers of I-DE.

The attacker could potentially have bypassed the security conditions of the exclusive information of I-DE, jumping to ranges of information from other companies.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

19/99

Given the nature of the database architecture (which, having logical separation, shares common physical elements), this could imply that other customer data belongs to different companies than i-DE, which is communicated to the Company's Systems Department for a detailed analysis of other impacts on other companies or businesses within the Iberdrola group."

2. Notifications of personal data breach made by IBERCLI:

A) On March 29, 2022 (Registration Number: REGAGE22e00010094106), IBERCLI submits a notification of a security breach, indicating that it became aware on March 28, 2022, that it was affected by the security breach suffered by I-DE, indicating the breach of confidentiality of personal data of 1,550,000 of its customers, whom it has not yet informed but will do so no later than 03/31/2022.

A) On April 6, 2022 (Registration Number: REGAGE22e00011889434), IBERCLI submits a modification of the personal data breach notification made on March 29, 2022, informing that the affected individuals are 1,515,000 and that they were informed on March 31, 2022, through communication directed personally to each affected individual (postal, email, SMS, or similar).

Along with the notification, the following is provided:

- Report "Cyberattack Incident 03/28/2022. Incident Description and Actions"
- Annex Communication to Interested Parties

3. Notification of personal data breach made by CURENERGIA:

A) On March 29, 2022 (Registration Number: REGAGE22e00010095169), CURENERGÍA submits a notification of a security breach, indicating that it became aware on March 28, 2022, that it was affected by the security breach suffered by I-DE, indicating the breach of confidentiality of personal data of 85,000 of its customers, whom it has not yet informed but will do so no later than 03/31/2022.

A) On April 6, 2022 (Registration Number: REGAGE22e00011892653), CURENERGÍA submits a modification of the personal data breach notification made on March 29, 2022, informing that the affected individuals are 92,550 and that they were informed on March 31, 2022, through communication directed personally to each affected individual (postal, email, SMS, or similar).

Along with the notification, the following is provided:

- Report "Cyberattack Incident 03/28/2022. Incident Description and Actions"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/99

- Annex Communication to Interested Parties

SECOND:

Circumstances of the Attack

1. As indicated in the summary of the report "Cyber Incident GEA. Incident Description and Actions." provided by IBERDROLA in the response to the information request made by this AEPD, during the preliminary investigation proceedings, submitted on January 24, 2023 (Registration Number: REGAGE23e00004670187), and as also indicated in the report "Cyber Incident GEA. Incident Description and Actions." dated March 28, 2022, and provided by I-DE along with the second notification of personal data breach, the timeline of the attack is as follows:

- "On March 15, in the afternoon, an attack against the management website of I-DE (GEA) is detected

☐

(...)

☐

(...)

☐

(...)

☐

(...)

☐

(...).

- On March 16, 2022, in the morning, a general slowdown of access to several websites of the Iberdrola group occurs.

☐

(...)

- From March 17:

☐

(...).

☐

From March 17, no suspicious traffic or impact is observed in any of the internet service systems of the

Iberdrola group

□

From the analysis of the activity log of the GEA application in the last days, it is concluded on March 17 that an exfiltration occurred, between March 7 and March 15, 2022, of approximately 4.5 million interested parties (natural persons).

□

Information regarding the customer codes of the interested parties was provided to I-DE by the Systems Department, which communicated on March 28, 2022, that of these, only 1.34 million records correspond to customers of I-DE.

□

On March 28, 2022, the Systems Department informs IBERCLI and CURENERGIA of the existence of a security incident in the systems of I-DE that may have affected the information related to the customers of these companies and includes information related to the internal customer codes of the affected individuals, in order for the companies

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/99

Verify whether data corresponding to their clients may have been compromised. After analyzing the information, IBERCLI and CURENERGIA confirm that the security breach has affected personal data of clients of these companies.

□

(...)

2. According to IBERCLI, in the report “Cyberattack Incident 28/03/2022. Incident Description and Actions.” dated April 4, 2022, and submitted along with the second notification of personal data breach, the chronology of events is as follows:

“3. Facts

Elements relating exclusively to the cyberattack on the GEA website of i-DE are excluded from this account, as we understand that the AEPD has already been informed of them.

The facts begin from the moment when IBERCLI becomes aware of being affected by the cyberattack:

1. On March 28, a notification is received from i-DE Systems indicating that, as a result of the analysis carried out by that company, it has been observed that among the affected clients, there are some that do not correspond to i-DE client codes.

2. After urgently analyzing the information provided, it is concluded that a total of 1.5 million clients of IBERCLI have been affected, despite the fact that the database architecture has implemented logical separation measures and each company, by application, only has the capacity to access its own clients.

3. Once the data breach affecting IBERCLI is confirmed, notification is made to the AEPD on March 29.

4. Work begins in parallel on notifying affected parties. This notification is carried out in waves between March 31 (approximately 400,000 notifications by email), April 1 (remaining notifications by email), and April 4 (sending letters to clients for whom no email is available). A customer support system is established for the affected clients, with a toll-free number and a specific email address, and the usual channels are reinforced by providing instructions to address specific inquiries about the incident. A copy of the communication sent is included in the annex.

5. IBERCLI has been integrated into a group-level plan at Iberdrola, which includes technical and organizational measures adopted to avoid, as much as possible, security incidents like the one that occurred. An urgent security plan has been launched for the entire Iberdrola group, consisting of:

a. Prevention (Infrastructure Controls)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

22/99

b. Detection of vulnerabilities

c. Remediation of detected vulnerabilities

d. Review of emergency protocols

6. The scope of digital surveillance established for the i-DE incident is extended to IBERCLI, with no publications detected to date in open sources or the dark web.”

3. According to CURENERGIA, in the report “Cyberattack Incident 28/03/2022. Incident Description and Actions.” dated April 4, 2022, and submitted along with the second notification of personal data breach, the chronology of events is as follows:

“3. Facts

Elements relating exclusively to the cyberattack on the GEA website of i-DE are excluded from this account, as we understand that the AEPD has already been informed of them.

The facts begin from the moment when CURENERGIA becomes aware of being affected by the cyberattack:

1. On March 28, a notification is received from i-DE Systems indicating that, as a result of the analysis carried out by that company, it has been observed that among the affected clients, there are some that do not correspond to i-DE client codes.

2. After urgently analyzing the information provided, it is concluded that a total of 92,550 clients of CURENERGIA have been affected, despite the fact that the database architecture has implemented logical separation measures and each company, by application, only has the capacity to access its own clients.

3. Once the data breach affecting CURENERGIA is confirmed, notification is made to the AEPD on March 29.

4. Work begins in parallel on notifying affected parties. This notification is carried out in waves between March 31, April 1, and April 4 (by email or by sending letters to clients for whom no email is available). A customer support system is established for the affected clients, with a toll-free number and a specific email address, and the usual channels are reinforced by providing instructions to address specific inquiries about the incident. A copy of the communication sent is included in the annex.

5. CURENERGIA has been integrated into a group-level plan at Iberdrola, which includes technical and organizational measures adopted to avoid, as much as possible, security incidents like the one that occurred. An urgent security plan has been launched for the entire Iberdrola group, consisting of:

a. Prevention (Infrastructure Controls)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/99

b. Vulnerability detection

c. Remediation of detected vulnerabilities

d. Review of emergency protocols

6. The scope of digital surveillance established for the i-DE incident is extended to CURENERGIA, with no publications detected to date in open sources or the dark web.

THIRD: Regarding the GEA application of I-DE

-i-de and IBERDROLA, in their responses to requests made by this AEPD, indicate:

- The GEA application is a web application of i-DE used for the Management of Electrical Connections; this application is published on the Internet for access by users (clients, installers, etc.) involved in the management process of these connection files:

***URL.1

- This service allows clients or their representatives (installers) to carry out the necessary procedures for the process of connecting to the network. During the sessions of the application, there is an exchange of client data information that is subject to the application's own security filters, so that each

client (or delegated representative) can only access information corresponding to the security and access profiles provided.

-(...):

***URL.2

FOURTH: Regarding the system architecture and database. Access from applications.

IBERDROLA, as the data processor managing the database where the three affected companies store their clients' personal data, indicates the following:

“(…)

(…).”

FIFTH: Causes that made the breach possible

IBERDROLA, in its response submitted on January 24, 2023, indicates:

(…)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/99

(…).

(…).

(…):

- (…)

- (…)

- (…)

- (…)

- (…)

- (…)

- (…)

- (…)

- (…)

(…)

(…)

SIXTH: Security measures established in the Database

IBERDROLA, regarding the security measures established in the database, in its response submitted on January 24, 2023, indicates the following:

“(…).”

SEVENTH: Immediate measures following the breach

IBERDROLA, in its response submitted on January 24, 2023, indicates the following:

“(…).”

EIGHTH: IBERDROLA as the data processor regarding IBERCLI and CURENERGÍA

In response to the information request made by this AEPD to IBERDROLA during the preliminary investigation period regarding the contracts signed in relation to data protection concerning the provision of IT support and security services provided to I-DE, IBERCLI, and CURENERGÍA, IBERDROLA, in its response submitted on January 24, 2023 (Registration Number:

REGAGE23e00004670187), indicates:

- “Document No. 1 is provided, Framework Agreement on the protection of personal data for the Iberdrola Group, which details the scope of the provision of services to the Group companies carried out by my represented entity, with the requirements established in Article 28 of the General Data Protection Regulation. This Agreement has been updated in its Annex II, which is provided as Document No. 1bis, with said update pending formalization.

Additionally, Document No. 2 is provided, a declaration of acceptance from Iberdrola España, S.A.U.

of its adherence to the aforementioned Framework Agreement, acting as indicated in the second clause, in its own name and right and on behalf of the companies belonging to its corporate group over which it holds direct or indirect control, including the three entities referred to in the information request.

The aforementioned "Framework Agreement on the protection of personal data for the Iberdrola Group," signed on May 18, 2018, is subscribed, on one side, by IBERDROLA and, on the other, by "the companies integrated into the group whose dominant entity, in the sense established by law, is IBERDROLA (hereinafter Iberdrola Group) that sign the Declaration of Acceptance which appears as Annex I to this contract...". In said agreement (hereinafter Framework Agreement PDP), the following is indicated:

In point 1 of the "Whereas":

"That the parties have signed a Framework Agreement for the Provision of Corporate Services regulating the provision of corporate services of (...) systems (...) under the Single Corporation Model by IBERDROLA to the beneficiary companies of the Iberdrola Group (...)

Point 11 "Therefore, this Framework Agreement on the Protection of Personal Data is established under which the access and processing of personal data by IBERDROLA and the Group Companies (service providers) on behalf of other Group Companies (service recipients) is legitimized, complying with the various applicable personal data protection legislations, especially the GDPR and the Spanish legislation governing the processing of personal data by IBERDROLA."

In the section "CLAUSES," it is indicated:

SECOND CLAUSE. In its second paragraph it states:

"(...)"

In said Annex, among other services, "Operation and support," "Development," and "System Management" are included.

In CLAUSE SEVEN "Guarantees in the processing of personal data," it is indicated:

"7.5.- Obligations of the Data Processor.

e) Security Measures.

In accordance with the GDPR, apply appropriate technical and organizational measures to ensure a level of security appropriate to the risk, taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

26/99

purposes of processing, as well as the variable probability and severity risks for the rights and freedoms of individuals.

The security measures to be implemented are those indicated in Annex III of this PDP Framework Agreement."

In response to the request for a copy of the record referred to in Article 30 of the GDPR, regarding the personal data processing activities of the aforementioned companies carried out under their responsibility, IBERDROLA responds:

"Documents numbered 3 and 4 include the Records of Processing Activities corresponding to the processing 'Support and Maintenance of IT Infrastructures' and 'Application Development (SWF)', carried out by my client in their capacity as data processor, regarding various processing activities of the Iberdrola Group companies, among which are those affected by the security breach:

- (...)

- (...)

IBERDROLA also indicates that "The Systems Directorate of the Iberdrola Group manages and operates the physical equipment that hosts the information, providing service to the different companies of the Group."

NINTH: Risk analysis of the processing affected by the personal data breach

At the request of this AEPD for a copy of the risk analysis on the rights and freedoms of individuals

conducted on the processing activity that suffered the security breach prior to the incident, both IBERCLI and CURENERGÍA provided the same document, which is the framework followed within the Iberdrola Group for assessing risk in the processing of personal data and is carried out in accordance with it:

(...)

Additionally, both companies attach an explanatory document of the logic followed for calculating the level of risk according to this methodology, titled "Logic for Calculating Risk Level."

They explain that this methodology is implemented in an automated manner in the corporate tool for recording processing activities, so that in the registration process itself, it determines the level of risk of the processing. Thus, the application of this methodology in relation to the processing (...) yielded a result of a MEDIUM risk level.

This document analyzes circumstances or threats in the sense of the indicated framework, which are transferred to the Records of Processing Activities.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

27/99

TENTH: Number of affected individuals and type of affected data

Affected IBERCLI customers: 1,515,000

Affected CURENERGÍA customers: 92,550

Type of affected data:

(...)

LEGAL GROUNDS

I

Competence

According to the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Data Protection Agency is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Data Protection Agency will be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

In this case, according to the provisions of Article 4.1 of the GDPR, there is evidence of the processing of personal data, given that IBERDROLA carries out, among other processing activities, the collection, storage, consultation, use, deletion, etc., of personal data of individuals, such as: name, surname, ID number, postal address, telephone number, email address, banking data, data related to electricity supply and consumption, bank account, etc.

IBERDROLA carries out this activity in its capacity as data processor, in accordance with Article 4.8 of the GDPR, since it processes this personal data on behalf of other companies belonging to the Iberdrola Group to which it provides, among other services, Support and Maintenance of IT Infrastructures and Application Development (SWF). Specifically, in the case at hand, it provides these services as a data processor, among others, for I-DE, CURENERGÍA, and IBERCLI.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

28/99

Article 4, paragraph 12 of the GDPR broadly defines "personal data security breaches" (hereinafter referred to as security breach) as "all breaches of security that result in the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data."

In this case, there is a personal data security breach under the circumstances mentioned above, categorized as a confidentiality breach, due to a cyber attack on a web application of one of the companies in the Iberdrola Group, which resulted in unauthorized access by a third party to personal data of two other companies in the same Group that were stored in the shared database managed and administered by IBERDROLA. Therefore, the security breach suffered has affected personal data processed by IBERDROLA in its capacity as data processor.

III

On the request for accumulation and the suspension of the deadline for submitting allegations Regarding the request for the accumulation of this file and EXP202205206 made by IBERDROLA, it should be noted that Article 57 of the LPACAP establishes:

"The administrative body that initiates or processes a procedure, regardless of the manner of its initiation, may, ex officio or at the request of a party, accumulate it with others that have substantial identity or intimate connection, provided that it is the same body that must process and resolve the procedure.

No appeal shall proceed against the accumulation agreement."

(the underlining is ours)

Therefore, it is a possibility available to the Administration, which is not obliged to proceed with the accumulation if requested. However, this does not prevent the subsequent motivation of the reasons why it has been deemed appropriate to process both sanctioning procedures separately.

Thus, although the two sanctioning files, one directed against I-DE and the other against IBERDROLA, S.A., stem from the same security incident (the attack on the GEA application, a web application of I-DE), it has resulted in two different and distinct personal data breaches, as reflected in the Background Facts of this proposal, especially in Background Fact Eight, where the information gathered during the preliminary investigation phase carried out by this AEPD is detailed.

Thus, on one hand, the attack occurred through a web application of I-DE, exploiting a vulnerability that allowed access to the I-DE database and affected the confidentiality of 1,350,000 I-DE customers. Therefore, the sanctioning procedure related to EXP202205206 is directed exclusively...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

29/99

a I-DE as the data controller of its clients' personal data and as a consequence of an existing vulnerability in one of its web applications.

On the other hand, the cyberattack not only affected personal data of I-DE, but also, by accessing I-DE's database, which was hosted on a system where databases of other companies in the same group coexist, the attacker, taking advantage of vulnerabilities in the databases, managed to access the databases of two other companies, IBERCLI and CURENERGÍA, affecting the confidentiality of personal data of clients of these two latter companies. These different databases of different companies are hosted or operated on a system maintained and supported exclusively by IBERDROLA, which, consequently, is responsible for processing all of them, that is, of I-DE, IBERCLI, and CURENERGÍA.

This fact has led to the initiation of the present sanctioning procedure against IBERDROLA, but for its responsibility as the processor of IBERCLI and CURENERGÍA and exclusively for the breach of personal data that has only affected the personal data of the clients of these two marketing companies, and only considering the responsibility that IBERDROLA may have regarding the configuration of the database it manages concerning these two affected companies.

In this regard, the impact on personal data of clients hosted in I-DE's databases cannot be part of this

sanctioning procedure directed exclusively at IBERDROLA, since I-DE is not responsible for the personal data of affected clients belonging to other companies, nor for the possible failure to adopt appropriate measures to protect the confidentiality of the personal data of other companies hosted in a database managed by IBERDROLA as the processor.

Therefore, the management of the databases carried out by IBERDROLA regarding those third companies must be analyzed independently, without I-DE being held accountable for possible breaches of data protection regulations in that management.

Thus, since the sanctioning procedures are directed at different subjects (two different companies), the personal data of clients of different companies are affected, and I-DE has nothing to do with the data of external clients, being processed for vulnerabilities or breaches regarding different systems (in one a web application of I-DE, in this one, a database managed by IBERDROLA), etc., it is for this reason that this AEPD has not considered accumulating the two files, but rather processing the two sanctioning procedures separately, as the responsibility attributed to each is clearly separated, as well as dealing with different personal data breaches affecting personal data processed by different controllers.

Furthermore, this does not leave IBERDROLA defenseless since at all times it is aware of the facts attributed to it, the infringement that they imply, the responsibility it has incurred, as well as that it has had and has the opportunity to make allegations and present any documentation it deems appropriate in defense of its interests as permitted by the applicable legislation.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
30/99

Finally, regarding the request for suspension of the deadline to submit allegations to the Initiation Agreement until a decision is made on the accumulation of the two proceedings, it is stated that such a possibility does not exist either in the applicable data protection regulations (GDPR and LOPDGDD) or in the LPACAP. On the contrary, this latter law establishes the obligation that the procedures to be completed by the interested parties are mandatory:

“Article 73. Compliance with procedures.

1. The procedures that must be completed by the interested parties must be carried out within ten days from the day following the notification of the corresponding act, unless a different deadline is set in the corresponding regulation.”

Therefore, the request for suspension is not appropriate, as this possibility does not legally exist, nor has it had any effect, and consequently, the deadline for submitting allegations has not been suspended.

IV

Response to the allegations to the Initiation Agreement

In response to the allegations presented, the following is noted:

FIRST: ON THE ACCUMULATION OF THE PROCEEDINGS

IBERDROLA reiterates the request for accumulation and refers to the request submitted for this purpose on May 24, 2023.

In this regard, it is appropriate to refer to what was argued in the previous Legal Basis, which adequately addresses this issue.

SECOND: ON THE SPECIAL CIRCUMSTANCES OCCURRED IN RELATION TO THE PROCESSING OF THE PRESENT FILE AND THE VIOLATION OF THE PRINCIPLES OF GOOD FAITH, LEGITIMATE EXPECTATION, AND LEGAL CERTAINTY

IBERDROLA alleges that this AEPD has violated the principles of legal certainty, good faith, and legitimate expectation established in Article 3.2 e) of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (hereinafter LRJSP) since, by means of a letter dated April 18, 2022, from the Division of Technological Innovation of the AEPD, it is indicated, in relation to the additional information provided by I-DE regarding the personal data breach suffered by it, that “After analyzing

the additional information provided, the security breach has been updated in the security breach notification register and no further actions are anticipated by this Agency.” However, subsequently and without any subsequent action recorded until the date of the first request for information directed to I-DE (letter signed on July 8, 2022, by the acting Inspector), it seems to be inferred that the AEPD initiated investigative actions, without any agreement or decision in this regard.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
31/99

IBERDROLA understands that this demonstrates that no additional investigation related to the breach was warranted, as the AEPD, by signing the aforementioned document of April 18, considered the statements made by I-DE, IBERCLI, and CURENERGIA to be adequate, not perceiving in the breach the presence of any element that would justify the initiation of investigative actions aimed at determining whether there had been a presumed violation of data protection regulations.

However, IBERDROLA continues, on May 9, 2022, the AEPD agreed to admit claims (filed prior to April 18, 2022) and to initiate preliminary investigative actions, but there is no record in the file of any action or circumstance related to this case that had been provided or occurred in the period between April 18 and the date of admission that would justify the initiation of the same.

Furthermore, IBERDROLA understands that the document of May 18, 2022, implies that the AEPD considered the information received from it regarding the breach to be sufficient to understand that there was no responsibility on the part of I-DE, IBERDROLA, or any other entity that had notified the incident for an alleged breach of data protection regulations, which determined the filing of a case that, however, the AEPD decided to open days later without any indication that implies a substantial change in the nature, circumstances, or severity of the breach. From this, IBERDROLA concludes that the AEPD made a decision that directly contradicts the previous one adopted just 20 days earlier.

In this regard, it should be noted, first of all, that the aforementioned document of May 18, 2022, was addressed solely to I-DE and related to the notifications made by it to the Technological Innovation Division of this AEPD as a result of a personal data breach suffered by it.

Therefore, this document in no way refers to the personal data breach suffered by IBERCLI and CURENERGIA, for which the present sanctioning procedure against IBERDROLA as the data processor is being processed, no matter how much it now attempts to extend it to this file.

It is noted in the resolution proposal that, notwithstanding the above, since the personal data breach notified by I-DE led to the breach suffered by IBERCLI and CURENERGÍA, a response is provided to the erroneous interpretation made by IBERDROLA regarding the aforementioned document.

Thus, this document is generically signed by the AEPD, comes from the Technological Innovation Division, which is responsible for receiving notifications of personal data breaches and registering them in the register maintained for this purpose, and in which the following was indicated:

“In relation to the additional information provided through entry register REGAGE22e00010072289, regarding a personal data breach at a...”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
32/99

Regarding the treatment of I-DE REDES ELECTRICAS INTELIGENTES S.A.U., we inform you that: After analyzing the additional information provided, the security breach has been updated in the security breach notification registry, and no further actions are anticipated from this Agency.

However, we remind you of the necessity to investigate the causes of the incident to understand how and why it occurred, and the obligation to take appropriate actions to prevent it from happening again and to minimize the potential impact on those affected, as well as the obligation to document any security incident that may affect personal data, including the facts related to it and the corrective measures taken, as established in Article 33.5 of the GDPR.

If, over time, you obtain indications that imply a substantial change in the nature, circumstances, or severity of the breach, you may submit a new complete notification through our electronic headquarters at <https://sedeagpd.gob.es/sede-electronica-web/>.

Additionally, we inform you that at the following link, you have access to the guide for managing and notifying personal data security breaches published by this Agency:

<https://www.aepd.es/media/guias/guia-brechas-seguridad.pdf>

The header states "DIVISION OF TECHNOLOGICAL INNOVATION."

On the left side of the document, it indicates "Electronically signed by: Spanish Agency for Data Protection. Dated 18/04/2022."

It is not signed by the Director of the Agency, it does not contain a dispositive part in which something is agreed or resolved, nor does it indicate any appeal against it.

Therefore, contrary to what IBERDROLA claims, this document does not have a decisive character, neither by its content, which only contains a forecast and cannot be understood to imply that this AEPD has assessed and decided that there was no responsibility on the part of I-DE or IBERDROLA (although we insist it is directed exclusively to I-DE) for an alleged breach of data protection regulations, which implies the filing of proceedings—as IBERDROLA has wanted to understand—nor by its form, as it does not even formally reflect a decision, much less a resolution to file any proceedings, since the only competent body for this is the current Director of the AEPD. Thus, Article 13 of the Statute of the AEPD, approved by Royal Decree 389/2021, of June 1, establishes the functions of the Presidency:

1. It is the responsibility of the Presidency of the Spanish Agency for Data Protection:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

33/99

d) To issue the resolutions and guidelines required for the exercise of the Agency's functions, particularly those arising from the exercise of the powers provided in Article 57 of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, and the exercise of the investigative powers and corrective powers provided in Article 58 of the aforementioned Regulation. Therefore, to proceed with the filing of investigative proceedings, it is required, first, that they have been initiated (either by admitting a complaint for processing or by the Agency's own initiative, which in both cases requires an express resolution signed by the Director), which had not occurred at the time the aforementioned document from the Division of Technological Innovation was issued, and, secondly, an express resolution from the Director is again necessary to archive said proceedings, understanding, now, that from the information gathered in those investigations, no infringement of data protection regulations is concluded, which had not occurred.

In this case, following the notification of the personal data breach by I-DE, CURENERGIA, and IBERCLI, several complaints were filed by individuals affected by the same, which were jointly admitted for processing by the AEPD in compliance with Article 64 of the LOPDGDD:

Article 64. Form of initiation of the procedure and duration.

1. When the procedure refers exclusively to the lack of attention to a request for the exercise of the rights established in Articles 15 to 22 of Regulation (EU) 2016/679, it will be initiated by an admission agreement, which will be adopted in accordance with the provisions of Article 65 of this organic law. In this case, the deadline for resolving the procedure will be six months from the date on which the admission agreement was notified to the complainant. After this period, the interested party may consider their complaint accepted.

2. When the procedure aims to determine the possible existence of an infringement of the provisions of Regulation (EU) 2016/679 and this organic law, it will be initiated by an initiation agreement adopted by its own initiative or as a result of a complaint.

If the procedure is based on a complaint filed with the Spanish Agency for Data Protection, prior to this, it will decide on its admission for processing, in accordance with the provisions of Article 65 of this

organic law.

When the rules established in Article 60 of Regulation (EU) 2016/679 apply, the procedure will be initiated by adopting the draft initiation agreement for sanctioning proceedings, which will be formally communicated to the interested party for the purposes provided in Article 75 of this organic law.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

34/99

Once the claim has been admitted for processing, as well as in cases where the Spanish Agency for Data Protection acts on its own initiative, prior to the initiation agreement, there may exist a phase of preliminary investigative actions, which will be governed by the provisions of Article 67 of this organic law.

Article 67. Preliminary Investigative Actions.

1. Before the adoption of the initiation agreement of the procedure, and once the claim has been admitted for processing, if applicable, the Spanish Agency for Data Protection may carry out preliminary investigative actions in order to achieve a better determination of the facts and circumstances that justify the processing of the procedure. The Spanish Agency for Data Protection will act in any case when it is necessary to investigate treatments that involve massive traffic of personal data.

2. The preliminary investigative actions will be subject to the provisions of Section 2 of Chapter I of Title VII of this organic law and may not exceed a duration of twelve months from the date of the admission agreement or from the date of the agreement by which its initiation is decided when the Spanish Agency for Data Protection acts on its own initiative or as a result of the communication that has been sent to it by the supervisory authority of another Member State of the European Union, in accordance with Article 64.3 of this organic law. (the underlining is ours)

From this regulation, it cannot be inferred in any way that the AEPD must justify, in the manner required by IBERDROLA, the initiation of preliminary actions in the sense that there must be something new or some new circumstance or that the claims must have provided new and different circumstances regarding the documentation provided by I-DE in its notification of the breach to this Agency, as this is not required by the indicated regulation, in addition to the fact that it cannot be expected that the affected parties provide something new, aside from knowing that the confidentiality of their personal data has been violated by a cyberattack whose circumstances they do not know. Precisely, the preliminary investigative actions are carried out to clarify the facts and circumstances of what has occurred, gathering more information in order to determine whether or not there is a possible infringement of the data protection regulations. In this sense, the initiation of preliminary investigations and their execution, a power of the AEPD with or without claims, does not prejudge anything, but allows for the gathering of the necessary information to determine whether there are indications of an infringement or not. Even after such an investigation, it may be that the actions are archived because, based on the information gathered, it is understood that there are no indications of an infringement. This has not happened in the present case.

What the regulation does indicate is that, after the submission of claims, this Agency must decide whether to admit them for processing or not, having finally decided on their admission through, this time, an Admission Agreement, signed by the Director of the Agency on May 9, 2022. And, as indicated in Article 67.2.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

35/99

In accordance with the LOPDGDD referenced, the AEPD may carry out preliminary investigative actions in order to achieve a better determination of the facts and circumstances. This is a power conferred to it by the GDPR and the LOPDGDD. Furthermore, and to elaborate on this point, even in

the event that no complaints had been made, the document from the Division of Technological Innovation would not have been an impediment or obstacle to the exercise of the investigative powers that the AEPD has in accordance with the aforementioned article 64.2, which states that “Once the complaint has been admitted for processing, as well as in cases where the Spanish Data Protection Agency acts on its own initiative, prior to the initiation agreement, there may be a phase of preliminary investigative actions...”

Therefore, the present sanctioning procedure has not been initiated due to the content or any new information provided in the complaints, but rather due to the information and documentation obtained after the period of preliminary investigative actions, from which possible violations of data protection regulations can be inferred.

On the other hand, IBERDROLA brings to attention the Judgment of the Supreme Court, dated February 22, 2016 (appeal 4048/2013), understanding that it is fully applicable to the case, in which it is indicated:

“In accordance with the facts briefly presented, we can consider legitimate trust to be violated, since the Administration cannot make decisions that contravene the perspectives and hopes founded on its previous decisions. When there is reliance on the stability of its criteria, evidenced in multiple previous acts in the same sense, which leads the administered party to make certain decisions, a trust based on the coherence of administrative behavior is generated, which cannot be disappointed by a surprising action. [...]

It is important to note that legitimate trust requires, ultimately, the concurrence of three essential requirements. Namely, that it is based on undeniable and external signs (1); that the hopes generated in the administered party must be legitimate (2); and that the final conduct of the Administration is contradictory to previous acts, being surprising and incoherent (3).

This is exactly what occurs in the case examined, in light of the facts previously recounted.

Let us remember that, regarding legitimate trust, we have repeatedly stated, among others, in the Judgment of December 22, 2010 (contentious-administrative appeal no. 257/2009), that “the principle of good faith protects the legitimate trust that may have been reasonably placed in the behavior of others and imposes the duty of coherence in one’s own behavior. This means that the principle implies the requirement of a duty of behavior that consists of the necessity to observe, looking to the future, the conduct that previous acts made foreseeable and to accept the binding consequences that arise from one’s own acts, constituting a case of injury to the legitimate trust of the parties ‘venire contra factum proprium’” (the underlining is ours)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

36/99

In this regard, it is indicated that the doctrine established therein is not applicable to the present case, since, as previously stated, it has neither been a decision of this Administration, nor by its form or content, nor have they caused reliance on the stability of its criterion, as there has been no criterion in this regard, much less evidenced in multiple previous acts in the same sense. Therefore, the actions of this Agency concerning the allegations made have not constituted a final conduct that is contradictory with previous acts that is surprising or incoherent, in the sense of the doctrine of the Tribunal.

Finally, regarding the reference made by IBERDROLA concerning the Agreement of the Director of the AEPD, dated May 9, 2022, which admits the claims filed against IBERCLI, in which reference is made to file AT/02233/2022, of which IBERDROLA states it is unaware, requesting to be informed whether any other type of procedure has been initiated against it and to which file it has not been granted access, it should be noted that under the cited file, the claims received from individuals affected by the personal data breach are grouped, which were admitted for processing jointly through the aforementioned Agreement, not constituting any file or procedure directed against IBERDROLA or against any of the companies comprising the Iberdrola Group.

In this regard, it is again recalled that such claims, being based on a personal data breach, are only admitted for processing, and this entails, as indicated, the possibility of initiating investigative actions to

clarify the facts and everything that has occurred, with the documentation and everything collected during such actions being what has exclusively motivated the initiation of the present sanctioning procedure, and not the aforementioned claims, which do not form part of this procedure. Furthermore, it is informed that no further processing of the same is carried out beyond communicating (not notifying) to the claimants the initiation, in this case, of a sanctioning procedure and also the resolution that results from it.

For the reasons stated, the allegation made is dismissed.

THIRD.- ON THE ADDITIONAL IMPACT ON THE PRINCIPLES OF SANCTIONING LAW DERIVED FROM THE INTERPRETATION MADE BY THE AEPD

IBERDROLA alleges in this section that the Initiation Agreement incurs significant violations of the principles of sanctioning administrative law, as it implies the imposition of two infringements whose content is, in reality, identical or regarding which, at the very least, one can appreciate the subsumption of one in the other:

1. Violation of the non bis in idem principle

IBERDROLA alleges that in the Initiation Agreement, the AEPD considers that the security measures implemented by it have not been, in its opinion, adequate and that this...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

37/99

implies a double violation of the GDPR, on the one hand, it understands that IBERDROLA has not adopted the appropriate technical and organizational measures required by Article 32 of the GDPR; and, on the other hand, it understands that the principle of security has been violated, allegedly breaching Article 5.1(f) of the GDPR, of which Article 32 is merely a specification.

IBERDROLA understands that this means that two differentiated sanctions are imposed, respectively, for considering that it lacks adequate security measures and because it believes that a breach of confidentiality of personal data has occurred due to the lack of such measures. Furthermore, it establishes for both alleged infringements identical modifying circumstances of IBERDROLA's liability, both in their determination and in the legal grounds for their imposition.

IBERDROLA points out that it follows from this that the AEPD considers that a single fact (the alleged insufficiency of security measures) would constitute two infringements of the same protected legal asset (the adequate guarantee of the rights and freedoms of the data subjects). This is because, on the one hand, the absence of the security measures that the AEPD considers necessary to adopt would be sanctioned, and, on the other hand, the principle of security and confidentiality, which requires the adoption of such measures, would also be sanctioned.

Therefore, IBERDROLA argues that, incurring in the triple identity of subject, fact, and protected legal asset, there is no doubt that the principle of non bis in idem has been violated, so that only one infringement can be attributed and sanctioned, which in this case would be solely under Article 32, as only the alleged insufficiency of security measures could be appreciated.

In response to this, it is necessary to explain the difference between the violation of Article 5.1(f) and Article 32 of the GDPR, which will be expanded upon in the next point regarding the allegation related to the existence of medial concurrence, as well as the different typification in even different sections of Article 83 of the GDPR and the different qualification of both for the purposes of prescription in the LOPDGDD.

Article 5.1(f) of the GDPR is violated when there is a loss of confidentiality, integrity, or availability of personal data, which may or may not occur due to the absence or deficiency of security measures.

This principle merely determines the channel through which the maintenance of confidentiality, integrity, or availability can be achieved when it specifies "through the application of appropriate technical and organizational measures," which are not strictly security measures.

IBERDROLA indicates that the appropriate technical and organizational measures referred to in Article 5.1(f) of the GDPR are the security measures of Article 32 of the GDPR. This would simplify the essence of the GDPR, whose compliance is not limited to the implementation of technical and

organizational security measures; it would mean, in our case, reducing the guarantee required by the principle of integrity and confidentiality to its achievement solely through security measures.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

38/99

When Article 5.1.f) of the GDPR refers to appropriate technical or organizational measures to ensure the rights and freedoms of data subjects within the framework of compliance management of the GDPR, it does so in the sense provided in Article 25 of the GDPR concerning data protection by design.

This provision states that,

“Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity posed by the processing to the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and to integrate the necessary safeguards into the processing, in order to meet the requirements of this Regulation and protect the rights of data subjects” (the emphasis is ours).

It should be noted that there are multiple technical or organizational measures that are not security-related and that the data controller can implement as a means to guarantee this principle. However, Article 32 of the GDPR includes the obligation to implement appropriate technical and organizational security measures to ensure a level of security appropriate to the risk. Of security. Only of security.

Moreover, its objective is to ensure a level of security appropriate to the risk regardless of whether a security breach has occurred, whereas in the case of Article 5.1.f) of the GDPR, confidentiality and integrity must be guaranteed, which in this case materializes with the loss of confidentiality of the data. As can be seen, the two articles pursue different purposes, although they may be related.

Delving directly into the examination of non bis in idem, the Judgment of the National Court of July 23, 2021 (rec. 1/2017) states that,

“(…) According to the legislation and jurisprudence outlined, the principle of non bis in idem prevents punishing the same subject twice for the same act based on the same grounds, understood as the same legal interest protected by the sanctioning norms in question. Indeed, when there is a triple identity of subject, act, and grounds, the sum of sanctions creates a penalty foreign to the proportionality assessment carried out by the legislator and materializes the imposition of a sanction not legally provided for, which also violates the principle of proportionality.

But for there to be talk of "bis in idem," there must be a triple identity between the compared terms: objective (same facts), subjective (against the same subjects), and causal (for the same grounds or reason for punishment):

a) The subjective identity implies that the affected subject must be the same, regardless of the nature or judicial or administrative authority that judges and with

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

39/99

independence of who the accuser is or the specific body that has resolved, or that is judged alone or in conjunction with other affected parties.

b) Factual identity implies that the facts being judged are the same, and rules out cases of real concurrence of infractions where there is not a single unlawful act but several.

c) The identity of foundation or causal identity implies that sanctioning measures cannot coincide if they respond to the same nature, that is, if they share the same teleological foundation, which occurs

between penal and administrative sanctions, but not between punitive and merely coercive measures.” Taking into account the aforementioned, the principle of non bis in idem has not been violated, since, although broadly understood, the facts are detected as a consequence of a personal data breach, the infringement of Article 5.1.f) of the GDPR is specified in a clear loss of confidentiality and availability, while the infringement of Article 32 of the GDPR is reduced to the absence and deficiency of the security measures (only security) detected, which are present independently of the personal data breach.

And all this in light of the allegations made by IBERDROLA, which considers that both provisions require a single conduct, which is to implement adequate security. This is not true, since Article 5.1.f) of the GDPR is not limited to guaranteeing security appropriate to the risk, but to guaranteeing integrity and confidentiality. And not only through security measures, but through all kinds of appropriate technical or organizational measures.

As indicated, Article 5.1.f) of the GDPR sanctions a loss of integrity and confidentiality, while Article 32 of the GDPR addresses the absence and/or deficiency of the security measures implemented by the data controller. Security measures that are absent or deficient, we add, that infringe the GDPR regardless of whether there has been a loss of confidentiality and integrity.

Finally, regarding the application of identical aggravating factors in both infringements, we must emphasize that the circumstances provided for in Article 83.2 of the GDPR and those established in Article 76.2 of the LOPDGDD are the only ones that can be applied by the AEPD for any infringement. What is decisive in this case, regarding that provided for in Article 83.2.b) of the GDPR, is not that they coincide in their use, but the foundation that is established for their consideration.

Having said all this, it is not considered that there is a violation of the principle of non bis in idem, enshrined in Article 25 of the Spanish Constitution.

2. Subsidiarily, existence of medial concurrence between the two behaviors attributed to IBERDROLA C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

40/99

IBERDROLA claims that, on the other hand, the Initiation Agreement identifies (and intends to sanction) a plurality of infractions that it allegedly committed (which it flatly denies) when, in reality, one of them would be subsumed and embedded in the other, giving rise to a medial concurrence in the terms provided in Article 29.5 of the LRJSP.

IBERDROLA understands that both infractions cannot be sanctioned, given that the commission of the alleged infraction of Article 32.1 of the GDPR would determine the supposed violation of Article 5.1.f) of the same legal text, and it would be sanctioning for the same facts, as it considers that the alleged infraction of Article 5.1.f) would necessarily and inseparably arise from the supposed lack of diligent implementation of the measures referred to in Article 32.1 of the GDPR.

IBERDROLA brings to attention certain jurisprudence (among others, Judgment 339/2015 of September 25, 2015, of the National Court - appeal 262/2014 - which cites the Judgment of the Supreme Court of February 8, 1999, - appeal 9/1996 -): “the application of medial concurrence requires a necessary derivation of some infractions with respect to others and vice versa, so it is essential that one cannot be committed without executing the other.” Thus, there must be “such a relationship between the concerned infractions that one necessarily derives from the other, so that it is not possible to commit one without executing the other” (among others, the Judgment of the National Court of December 26, 2013, - appeal 416/2012). Therefore, I-DE concludes that it is evident that such a relationship exists between the two infractions that are intended to be imputed against it.

In this regard, it is noted, as previously mentioned, that Article 32 of the GDPR, while related to Article 5.1.f) of the GDPR, does not encompass the principle in its entirety.

Thus, Article 5.1.f) of the GDPR is one of the principles related to processing. The principles related to processing are, on one hand, the starting point and the closing clause of the legal framework for data protection, constituting true guiding rules of the system with intense expansive force; on the other hand, having a high level of specificity, they are mandatory norms that can be infringed.

Well then, Article 5.1.f) of the GDPR encompasses the principle of integrity and confidentiality and determines that personal data shall be processed in such a way as to ensure an adequate level of security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures of all kinds, not only security measures.

On the other hand, Article 32 of the GDPR regulates how the security of processing should be articulated concerning the specific security measures that must be implemented, in such a way that, taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the variable probability and severity risks for the rights and freedoms of natural persons, the data controller and the processor shall apply appropriate technical and organizational measures to ensure a level of security appropriate to the risks.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

41/99

risk that includes, among other issues, the ability to ensure the confidentiality of the data.

As noted, this provision, Article 32 of the GDPR, although related to Article 5.1(f) of the GDPR, does not encompass the principle in its entirety. Article 5.1(f) of the GDPR explicitly requires that confidentiality be guaranteed and necessitates a loss of confidentiality for its application. We may encounter situations where inadequate measures exist without a resulting loss of integrity and confidentiality.

Evidence of this is not only the difference between the violation of Article 5.1(f) and Article 32 of the GDPR but also the different classifications in even distinct sections of Article 83 of the GDPR and the different qualification of both for the purposes of prescription in the LOPDGDD.

In the case examined, as stated in the proven facts, there is a clear loss of confidentiality demonstrated through a clear outcome: there was unauthorized access by a third party to personal data.

Furthermore, as indicated, Article 5.1(f) of the GDPR is violated when there is a loss of confidentiality or integrity of personal data, which may or may not occur due to the absence or deficiency of strictly security measures.

This principle merely determines the channel through which the maintenance of confidentiality, integrity, or availability can be achieved when it explicitly states "through the application of appropriate technical and organizational measures," which are not strictly security measures.

IBERDROLA indicates that the appropriate technical and organizational measures referred to in Article 5.1(f) are the security measures of Article 32 of the GDPR. This would simplify the essence of the GDPR, whose compliance is not limited to the implementation of technical and organizational security measures; it would mean, in our case, reducing the guarantee required by the principle of integrity and confidentiality to its achievement solely through security measures.

As previously noted, when Article 5.1(f) of the GDPR refers to appropriate technical or organizational measures to guarantee the rights and freedoms of data subjects within the framework of compliance management of the GDPR, it does so in the sense provided in Article 25 of the GDPR regarding privacy by design.

We reiterate that there are multiple technical or organizational measures that are not security-related and that the data controller can implement as a means to guarantee this principle.

And all this in response to the allegations made by IBERDROLA, which considers that both provisions require a single conduct, which is to implement adequate security. This is not true, as Article 5.1(f) of the GDPR is not confined to...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

42/99

the guarantee of adequate security to the risk, but rather the guarantee of integrity and availability. And not only through security measures, but through all kinds of appropriate technical or organizational measures.

As we have indicated, Article 5.1.f) of the GDPR penalizes a loss of integrity and confidentiality, and Article 32 of the GDPR addresses the absence and deficiency of security measures implemented by the data controller. We add that absent or deficient security measures infringe the GDPR regardless of whether a loss of confidentiality and integrity has occurred or not.

In the present case, the aforementioned Article 32 has been violated regardless of whether a confidentiality breach has ultimately occurred or not, because the reprehensible conduct that violates this provision is the lack or inadequacy of those measures in themselves; that is, it is infringed and sanctioned regardless of whether a personal data breach has occurred or not. This does not preclude that, in the event of a materialization of a personal data breach, this circumstance may be considered an aggravating factor, in accordance with the GDPR.

On the contrary, in the present case, for us to be facing a violation of Article 5.1.f), it has been and is an unavoidable requirement that the confidentiality of personal data is violated (which does not happen with the violation of Article 32).

Regarding the medial concurrence, it should be noted that Article 29 of the LRJSP does not apply to the sanctioning regime imposed by the GDPR. This is because:

1. The GDPR is a complete system.

The GDPR is a directly applicable community regulation in the Member States, which contains a new, complete, and global system aimed at ensuring the protection of personal data uniformly throughout the European Union.

In relation specifically and also to the sanctioning regime provided therein, its provisions apply immediately, directly, and integrally, providing a complete and gapless system that must be understood, interpreted, and integrated absolutely, completely, and integrally, thus preserving its ultimate purpose, which is the effective and real guarantee of the Fundamental Right to the Protection of Personal Data. The contrary results in a diminishment of the guarantees of the rights and freedoms of citizens.

In fact, a specific example of the non-existence of gaps in the GDPR system is Article 83 of the GDPR, which determines the circumstances that may operate as aggravating or mitigating factors regarding an infringement (Article 83.2 of the GDPR) or specifies the existing rule regarding a possible medial concurrence (Article 83.3 of the GDPR).

To the above, we must add that the GDPR does not allow for the development or specification of its provisions by the legislators of the Member States, except for what the European legislator has specifically provided, delimiting it very concretely (for example, the provision of Article 83.7 of the GDPR). The LOPDGDD only

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

43/99

develops or specifies certain aspects of the GDPR in what it allows and to the extent that it allows.

This is so because the intended purpose of the European legislator is to implement a uniform system throughout the European Union that guarantees the rights and freedoms of individuals, corrects behaviors contrary to the GDPR, promotes compliance, and enables the free movement of these data.

In this regard, Recital 2 of the GDPR states that,

“(2) The principles and rules regarding the protection of individuals with regard to the processing of their personal data must, regardless of their nationality or residence, respect their fundamental freedoms and rights, in particular the right to the protection of personal data. This Regulation aims to contribute to the full realization of an area of freedom, security, and justice and of an economic union, to economic and social progress, to the strengthening and convergence of economies within the internal market, as well as to the well-being of individuals.” (the underlining is ours)

It further indicates in Recital 13 of the GDPR that,

“(13) To ensure a consistent level of protection for individuals throughout the Union and to avoid divergences that hinder the free movement of personal data within the internal market, a regulation is necessary that provides legal certainty and transparency to economic operators, including micro-enterprises and small and medium-sized enterprises, and offers individuals from all Member States the same level of enforceable rights and obligations and responsibilities for controllers and processors, in order to ensure consistent supervision of personal data processing and equivalent sanctions across all Member States, as well as effective cooperation between the supervisory authorities of the different Member States. The proper functioning of the internal market requires that the free movement of personal data in the Union is not restricted or prohibited for reasons related to the protection of individuals with regard to the processing of personal data.” (the underlining is ours)

In this system, what is decisive in the GDPR is not the fines. The corrective powers of the supervisory authorities provided for in Article 58.2 of the GDPR combined with the provisions of Article 83 of the GDPR show the prevalence of corrective measures over fines.

Thus, Article 83.2 of the GDPR states that “Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j).”

In this way, the corrective measures, which are all those provided for in Article 58.2 of the GDPR except for the fine, take precedence in this system, relegating the economic fine to cases where the circumstances of the specific case determine that a fine is imposed along with the corrective measures or in substitution of them.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

44/99

And all this with the aim of enforcing compliance with the GDPR, preventing non-compliance, promoting adherence, and ensuring that the infringement is not more profitable than compliance.

Therefore, Article 83.1 of the GDPR states that “Each supervisory authority shall ensure that the imposition of administrative fines pursuant to this Article for the infringements of this Regulation referred to in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.” (the underlining is ours)

For this system to function with all its guarantees, it is necessary that several elements are deployed in an integral and complete manner. The application of rules external to the GDPR regarding the determination of fines in each of the Member States applying their national law, whether due to aggravating or mitigating circumstances not provided for in the GDPR - or in the LOPDGDD in the case of Spain - or due to the application of a different mitigating circumstance than that provided in the GDPR, would undermine the effectiveness of the system, losing its meaning and teleological purpose, resulting in fines imposed for different infringements ceasing to be effective, proportionate, and dissuasive. In this way, it would also deprive the interested parties of the effective guarantee of their rights and freedoms, weakening the uniform application of the GDPR. The mechanisms for protecting the rights and freedoms of citizens would be diminished, which would be contrary to the spirit of the GDPR.

The GDPR is endowed with its own principle of proportionality that must be applied in its strict terms.

2. There is no legal gap, there is no supplementary application of Article 29 of the GDPR.

In addition to the above, it should be noted that there is no legal gap regarding the application of mitigating circumstances. Neither the GDPR allows nor does the LOPDGDD provide for the supplementary application of the provisions of Article 29 of the LRJSP.

There is also no subsidiary application of Article 29 of the GDPR. In Title VIII of the LOPDGDD relating to “Procedures in the event of a possible breach of data protection regulations,” Article 63 that opens the Title states that “The procedures processed by the Spanish Data Protection Agency shall be

governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures." While there is a clear reference to the LPACAP, there is absolutely no establishment of a subsidiary application regarding the LRJSP, which does not contain any provision related to any administrative procedure.

Just as the AEPD is not applying the aggravating and mitigating factors provided in Article 29 of the LRJSP, since the GDPR establishes its own, therefore, there is no legal gap nor subsidiary application of the same, nor can the section relating to mitigating circumstances be applied for the same reasons.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
45/99

In any case, the judicial precedents cited by the claimant regarding medial competition derive from the application of the LOPD of 1999, which transposed Directive 95/46/EC, establishing the GDPR a clearly different system. At that time, Article 115 of Royal Decree 1720/2007, of December 21, which approves the Regulation for the development of Organic Law 15/1999, of December 13, on the protection of personal data, did provide for a supplementary application of Law 30/1992, of November 26, on the Legal Regime of Public Administrations and the Common Administrative Procedure.

Thirdly, and focusing on the specific case examined, and without prejudice to the above, it should be highlighted that there is no medial competition. Article 29.5 of the LRJSP establishes that "When the commission of one infringement necessarily results in the commission of another or others, only the sanction corresponding to the most serious infringement committed shall be imposed."

Well, medial competition occurs when, in a specific case, the commission of one infringement is a necessary means to commit another distinct infringement.

The established facts determine the commission of two distinct infringements, without the violation of Article 32 of the GDPR (security of processing), as asserted by the appealing party, being the necessary means by which the infringement of Article 5.1.F) of the GDPR (principle of confidentiality) occurs.

In conclusion, from all of this and contrary to all that has been argued, it has been proven that I-DE was not diligent as it did not adequately guarantee the confidentiality of its clients' personal data, nor did it have the appropriate technical and organizational measures to ensure an adequate level of security.

For the reasons stated, the allegation is dismissed.

FOURTH.- ON THE ALLEGED VIOLATION BY IBERDROLA OF ARTICLE 32 OF THE GDPR
IBERDROLA claims not to agree with the indication in the Initiation Agreement that it did not have appropriate security measures to ensure a total separation between the personal data of the different companies for which it acts as data processor, as it argues that, as it has been demonstrating in the responses given to the AEPD in the various information requests, it has been proven that it had implemented robust security systems that (...).

IBERDROLA then proceeds to detail again how access to the information contained in the database works for the different applications.

Thus, according to what has been indicated, the database where the personal data of clients of the different companies of the Iberdrola Group is stored is (...).

However, (...)

(...):

C/ Jorge Juan, 6
www.aepd.es

28001 – Madrid
sedeagpd.gob.es
46/99
-(...).
-(...).

Therefore, although it is indicated that the client code is not accessible to users, it is no less true that if a transaction is generated with the CLIENT table using the "client code," it does not carry the prior filter of "Company Code," and thus it is possible to access personal data of other companies once the client code indicated in the URL corresponds to the client of another company with which there is only this logical separation. Therefore, it was allowed that by modifying the client code in the URL of this web application, access could be gained to personal data of clients from other companies with which there is no relationship and against which it is mandatory to safeguard their confidentiality from unauthorized third parties.

In other words, with or without a cyberattack, what is reflected is that by modifying that code in the URL, the implemented logical separation was circumvented. Therefore, it was not adequate or was insufficient, which constitutes a violation of Article 32, as it reflects a lack or insufficiency of appropriate measures to ensure adequate security, according to the risk, in the processing of personal data. IBERDROLA seems to argue that the responsibility lies with the cybercriminal for exploiting a vulnerability in a web application. However, if the logical separation had been adequate (or if there had been physical separation), the attack would have been confined exclusively to the clients of I-DE. The vulnerability exploited by the attacker was that the client code was visible in the URL and that, furthermore, it was allowed to modify that URL by making calls to the CLIENT table and thus access the personal data stored in that table.

That it then allowed access to personal data of clients from other companies is a consequence of a deficient logical separation in the database. This deficiency is precisely in allowing the internal code of GEA, the "COD_CLIENTE," to generate transactions with the CLIENT table without carrying the prior filter of "Company Code." This was permitted because that is how it was configured (and, according to IBERDROLA's statements, it is also established in the applications of the other companies that share the CLIENT table and the same logical separation).

Therefore, the cybercriminal did not exploit that vulnerability in the logical separation in the affected table, but rather stumbled upon it.

In this regard, it is unacceptable that, under any circumstances, access can be gained from an application of one company to the personal data of clients of other companies. This is the responsibility of IBERDROLA, as the data processor, manages the Group's database.

On the other hand, IBERDROLA claims that the AEPD has linked the alleged breach of Article 32 with the outcome that occurred as a result of the concurrence of a series of factors that were unpredictable and that were detected and resolved immediately. Therefore, it concludes that the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
47/99

The AEPD is imposing, with respect to the adoption of security measures, an obligation of result, but it is, however, an obligation of means. In this regard, it refers to what was stated by the Supreme Court in its judgment of February 15, 2022 (cassation appeal 7359/2020), which clearly indicates that the obligation imposed by the personal data protection regulations to adopt technical and organizational measures aimed at ensuring the confidentiality, availability, and integrity of the information is an obligation of means and not of result.

In this respect, it should be noted that the aforementioned Judgment indeed indicates, regarding security measures in the field of data protection, that "... the obligation that falls on the data controller and the data processor regarding the adoption of necessary measures to ensure the security of personal data is not an obligation of result but of means, and the infallibility of the adopted measures is not required. Only the adoption and implementation of technical and organizational measures, which

according to the state of technology and in relation to the nature of the processing carried out and the personal data in question, reasonably allow for the prevention of their alteration, loss, unauthorized processing, or access is required.” (the emphasis is ours)

However, the Judgment continues by indicating, in the specific case being analyzed, that “...the program used for collecting customer data did not contain any security measures that would allow verifying whether the email address entered was real or fictitious and whether it actually belonged to the person whose data was being processed and who provided consent for it. The state of technology at the time these events occurred allowed for the establishment of measures aimed at verifying the authenticity of the email address, conditioning the continuation of the process on the user receiving the contract at the provided address and only from there giving the necessary consent for its collection and processing. Measures that were not adopted in this case.

(...) Thus, at the time these events occurred, there were technical measures related to the registration process that would have prevented the personal data breach that occurred. This implies that the technical measures adopted did not comply with the security conditions as required in Article 9.1 of Law 15/1999, thus incurring the infringement provided for in Article 44.3.h) consisting of "Maintaining files, premises, programs, or equipment containing personal data without the due security conditions determined by regulation [...]".

(...) It is stated that the technical security measures related to the software program were the responsibility of Telefónica Consumer Finance, which designed the program and was responsible for the file and processing, and that the sanctioned company only acted on its behalf collecting data from customers who opted for financing. The truth is that the data processor - the natural or legal person who, alone or jointly with others, processes personal data on behalf of the data controller, Article 4, paragraph 8 of the Regulation, as well as Article 3.g) of Law 15/1999, and the collection of data implies processing (Article 3.c) - must also adopt the necessary technical and organizational measures to ensure...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
48/99

to guarantee the security of personal data, as provided for in Article 32.1 of Regulation (EU) 2016/679 of the Parliament and of the Council and Article 9.1 of the LOPD, and is subject to the sanctioning regime established in the Law (Article 43 of the LOPD 15/1999).

The appealing company processed customer data on behalf of the data controller, which is why it implemented and used said program, being aware, or should have been aware, that it lacked the necessary security measures...” (the underlining is ours)

Therefore, although it is inferred from the Judgment that the obligations established by Article 32 of the GDPR are of means, it also makes it clear that if, at the time of the incident, there were adequate technical measures in place to prevent or mitigate its effects and they were not applied, this constitutes a breach of the aforementioned obligation imposed by the GDPR and, consequently, an infringement thereof.

In the present case, as noted, there was a vulnerability or a misconfiguration of access to the database managed by IBERDROLA as the data processor, which was also avoidable since it could have been configured differently or, as it has indicated it plans to do, proceed to separate the systems that use the common infrastructure of the data centers, that is, proceed to store the personal data of the affected companies in exclusive and separate tables.

This clearly demonstrates a breach of Article 32 of the GDPR, as it requires appropriate measures to ensure a level of security appropriate to the risk, taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing.

IBERDROLA also argues that the security breach does not stem from the insufficiency of the measures adopted, but from the intense activity carried out by a third party with the sole intention of carrying out the cyberattack that harmed not only the customers of the Group's companies but also the companies themselves that suffered it.

In this regard, it should be noted that total infallibility of the measures that can be adopted to ensure adequate protection in the processing of personal data has not been required. However, once the attack has occurred, the diligence of the controllers and processors in applying the appropriate technical and organizational measures to ensure a level of security appropriate to the risk must be evaluated, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing.

In the present case, IBERDROLA did not have, at the time of the data protection breach, the appropriate measures in relation to the risks of processing for the protection of personal data, as indicated, there was a vulnerability in the configuration of access to the database managed by IBERDROLA as the data processor.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

49/99

Lastly, in accordance with the Judgment of June 22, 2021 - Rec. 1210/2018, and the Judgment of November 5, 2011 - Rec. 1796/2019, which evaluates the subjective or culpability element, it is emphasized that the culpability of the plaintiff cannot be considered excluded or mitigated by the fact that there was fraudulent action by a third party, as the responsibility of the plaintiff does not derive from the actions of this third party, but from their own actions.

Finally, IBERDROLA points out that it had mechanisms in place that allowed for the almost immediate detection of the personal data breach suffered, adopting immediate measures, and therefore understands that its swift action is a clear example of full compliance with the provisions of Article 32.1 c) of the GDPR, when it refers to "the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident," something that, however, has not been sufficiently valued by the Initiation Agreement.

In this regard, both in the Initiation Agreement and in the present proposal, it has been taken into account that IBERDROLA, through the Systems Directorate, reacted as quickly as possible and proceeded to take measures aimed at repelling the attack and preventing its recurrence, considering it as a mitigating circumstance in accordance with Article 83.2.c) GDPR.

Finally, IBERDROLA indicates that Article 82.2 of the GDPR establishes in its second paragraph that "[a] processor shall only be liable for damages caused by processing when it has not complied with the obligations of this Regulation specifically directed to processors or has acted outside or contrary to the lawful instructions of the controller."

While IBERDROLA points out that this rule is included within the provisions contained in the GDPR related to the right to compensation and liability, it considers that if it cannot be deemed that a processor, such as itself, should be liable for damages that may have been suffered by data subjects as a result of processing, provided that it has complied with the obligations imposed on it as a processor by the GDPR, it would also not be possible to hold it liable in the sanctioning sphere. Therefore, IBERDROLA recalls that it has fully complied with the obligations imposed on it by the GDPR as a processor of i-DE, IBERCLI, and CURENERGIA, following in all cases their instructions and adopting, in particular, the security measures required to prevent the loss of availability, integrity, or confidentiality of the data for which each of these companies is responsible, which would necessitate the filing of the present procedure.

In this regard, reference should be made to all that has been indicated previously in this Legal Basis, as it reflects that IBERDROLA, as the data processor managing and administering the database affected by the cyberattack, did not comply with its obligations regarding the adoption of technical measures and

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

50/99

appropriate organizational measures to ensure an adequate level of security relative to the risk, which in this case included, among others, the ability to guarantee the confidentiality, integrity, availability, and permanent resilience of the processing systems and services as required by Article 32 of the GDPR.

For the reasons stated, the allegation made is dismissed.

FIFTH. – ON THE ALLEGED VIOLATION OF THE SECURITY PRINCIPLE

In this section, IBERDROLA argues that there has been no evidence, even circumstantial, of the fraudulent use of personal data, as the Initiation Agreement merely considers that there is a very high risk and that it has not materialized in practice.

In this regard, it is necessary to clarify that what is attributed to IBERDROLA is the violation of the confidentiality principle, as it is established that, after suffering a cyber attack against the GEA website of the company I-DE, in addition to an unlawful access to personal data processed by it, there was also an unauthorized access to personal data – and the extraction of the same – by a third party, which resulted in the loss of confidentiality and control of numerous personal data (...) and affected 4,515,000 customers of IBERCLI and 92,550 customers of CURENERGIA.

This constitutes a breach of the duty to guarantee the confidentiality of personal data, as indicated, Article 5.1.f) states that personal data must be processed in such a way as to ensure an adequate level of security, including protection against unauthorized or unlawful processing.

Regarding the indication of the high risk that such data, in the hands of cybercriminal(s), could be used fraudulently, this was stated to express what the loss of confidentiality entails, but it is not necessary in any way, to understand that Article 5.1.f) has been infringed, for such risks of fraudulent use to materialize, because what has materialized with the breach is the loss of confidentiality of personal data, which is what is exclusively attributed.

On the other hand, IBERDROLA insists again in this section that it understands that the AEPD considered the breach reported by it to be archived and that the claims do not provide anything new and that, therefore, nothing seems to justify the reopening of the investigation when it had been archived.

In this regard, reference should be made to all that has already been argued in relation to this in Section Two of this Legal Basis.

Therefore, the allegation made is dismissed.

SIXTH. – ON THE VIOLATION OF THE PROPORTIONALITY PRINCIPLE TO THE DETRIMENT OF IBERDROLA'S RIGHTS

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

51/99

IBERDROLA claims that the imposed sanctions violate the principle of proportionality, as the AEPD, in determining the amount of the sanctions, has relied on completely generic criteria.

Thus, regarding the alleged negligence in its actions, IBERDROLA indicates that it has demonstrated that the events in question occurred at a specific moment and were resolved very quickly, so the measures adopted in response to the incident mitigated its effects. This immediate resolution of the incident shows that they indeed had planned actions in the event of a possible attack on their systems. In contrast, it should be noted that the appropriate technical and organizational measures to ensure an adequate level of security against the risks that personal data processing may pose to the rights and freedoms of individuals cannot be merely reactive measures, that is, to immediately address a personal data breach. Thus, Article 32 of the GDPR not only states that adequate security must be ensured, but also that such measures must include the ability to guarantee the ongoing confidentiality, integrity, availability, and resilience of processing systems and services (letter b of Article 32.1 GDPR). Therefore, it is not enough to have measures to react as quickly as possible when confidentiality has been breached; there must also be adequate preventive measures in place to prevent such a breach. This is because measures aimed at safeguarding the confidentiality, integrity, and availability of personal data—namely, preventive measures aimed at avoiding any breach—are equally or even

more important.

Therefore, it cannot be accepted that the measures implemented by IBERDROLA were adequate simply because they allowed for the resolution of the incident afterward, as this only demonstrates the existence of corrective measures. However, what those reactive measures allowed was the cessation of the attack once it had occurred and the restoration of the service; that is, in terms of the protection of personal data, it prevented a greater impact, and this has already been taken into account as a mitigating factor in the current sanctioning procedure, but in no way can they remedy the loss of confidentiality of the affected personal data, as this had already materialized.

In other words, the confidentiality of personal data is primarily guaranteed through preventive measures. In this regard, it has already been indicated in the response to the Fourth Allegation of this Legal Basis the absence of adequate technical and organizational measures to ensure the proper separation of the personal data of customers from at least three different companies.

Therefore, all of this merely reflects a lack of diligence on the part of IBERDROLA in ensuring adequate security against the risks of the data processing it carries out. In this sense, it should not be forgotten that the affected database contains personal data of millions of customers, which constitutes large-scale processing, and that, in turn, is accessed from web applications, that is, from the internet, which requires adequate security measures specifically aimed at ensuring that there is no unauthorized access to such personal data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

52/99

On the other hand, IBERDROLA states that it does not agree with considering the connection of its activity with the processing of personal data as an aggravating factor, as it believes that its conduct is being aggravated simply due to its belonging to the electricity sector, and that it should not be required to exercise special diligence because of this, which again violates the principle of proportionality.

In response, it is emphasized that its conduct is not aggravated by belonging to the electricity sector, but rather because its activity, the development of its business, involves and requires continuous and extensive processing of personal data, as evidenced by the fact that it processes data of millions of people.

Therefore, as indicated in the Initiation Agreement, IBERDROLA is a company accustomed to processing personal data, which again entails the requirement of a higher degree of diligence.

On the other hand, it is noted that Article 83.2 of the GDPR states that “When deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

(...)

k) any other aggravating or mitigating factor applicable to the circumstances of the case...”.

In this regard, the Spanish legislator has considered it appropriate to include in Article 76 of the LOPDGDD that: “2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

(...)

b) The connection of the infringer's activity with the processing of personal data.”

This Agency simply takes that circumstance, as provided by the legislator, into consideration when deciding on the imposition of the administrative fine.

It is noteworthy that, for the purposes of deciding on the imposition of an administrative fine, an infringement committed by a natural person or a small company not accustomed to processing personal data cannot be given the same consideration as that of a large company like IBERDROLA, which is used to processing personal data of millions of clients and has a long history in this regard. Of course, it is considered that the infringement is more serious for the purposes of imposing a fine if the data controller falls into the latter category, as is the case with IBERDROLA.

On the other hand, it argues the lack of proportionality by comparing it with case PS/00179/2020, in which it indicates that it was only fined 500,000 euros despite the fact that not only was confidentiality

breached, but the breach was not reported to the AEPD, which IBERDROLA has done; however, the penalty is considerably lower.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
53/99

In this regard, it should be noted, on the one hand, that in the area of data protection, the technical and organizational security measures to be adopted by the data controllers and other obligations to be fulfilled as required by the GDPR must be appropriate in relation to the specific risks posed by the specific processing carried out by each controller. Therefore, when analyzing the diligence of each party in complying with the regulations, the circumstances of each case must be taken into account, considering the nature, scope, context, and purposes of each processing, and thus there are no identical cases.

On the other hand, Article 83 establishes that

1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed based on the circumstances of each individual case..." (The underlining is ours)

Therefore, attention must be paid to the circumstances of each individual case, as there are no two identical files and, consequently, no identical outcomes. For example, in the file that is referenced, the affected parties were less than half of those in the case currently under consideration; the infringement of Article 32 of the GDPR was due to another type of insufficiency in the measures to ensure adequate security for the processing; the events occurred in 2018, the year in which compliance with the GDPR became mandatory, which is not the same as four years later; the knowledge of the technique is not the same a few years before and after, especially due to its rapid advancement, etc.

It is also noted that there are many other files, both prior to and subsequent to the present one, in which high fines have been imposed for both the violation of data confidentiality and the infringement of the security measures of Article 32 of the GDPR, although, as noted, the specific circumstances of each case must always be taken into account.

Finally, and to further elaborate, it is not appropriate to demand equality in illegality. The jurisprudence is clear on this matter. Thus, the Judgment of the National Court of April 28, 2023 (SAN 28.04.2023 REC. 409/2021) indicates that "A discriminatory sanctioning treatment is referred to since that fine or economic sanction can be replaced by the measures of Article 58 GDPR, less burdensome measures such as a warning. And it refers to other infringements committed by other entities. Of course, the plaintiff tries to compare this situation with another sanctioning procedure that is mentioned, but we are not facing discriminatory treatment or a violation of the principle of equality since it is a principle that only operates within the framework of legality when identical factual situations are treated differently without reasonable justification. As stated in the Supreme Court ruling of January 20, 2004, "equality must be asserted within legality, so that if the correct action of the Administration is the one now being judged, as we have declared, the one invoked as contrary to it was not, and therefore, it cannot be invoked to request that the appellant be treated equally, since, as this Chamber of the Court..."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
54/99

The Supreme Court has declared in its rulings of June 16, 2003, July 14, 2003, and October 20, 2003, that "the principle of equality lacks significance to support a situation contrary to the legal order," and this, as indicated by the ruling chamber itself, regardless of the fact that the alleged administrative action contradicting the present has not been substantiated.

In the same vein, the Supreme Court ruling of April 2, 2014 (Rec. 1916/2010) states that "legality

prevails over a possible violation of the principle of equality." In this case, we are faced with an administrative infraction that is intended to be compared with another that has had a different resolution, but from what can be observed in the allegation made by the plaintiff, it is hardly possible to make a comparison between one situation and another. Let us remember that according to the consolidated constitutional doctrine, to appreciate the concurrence of a violation of the principle of equality, the following prerequisites must be met: 1) provision of an appropriate term of comparison demonstrating the substantial identity of the legal situations that have received different treatment, 2) that the unequal treatment is not based on objective reasons that justify it, and 3) that the comparative judgment is developed within the framework of legality, as the principle of equality cannot be invoked in illegality to perpetuate situations contrary to what is provided by the legal order. Given these circumstances, the conduct for which the plaintiff has been sanctioned and which is contrary to law does not allow for their responsibility to be mitigated by the fact that in other cases, which are unknown, the imposed sanction was not economic and was considered more beneficial. For all the above reasons, the allegation made is dismissed.

V

Response to the allegations regarding the Proposal for Resolution

In response to the allegations presented by IBERDROLA, the following should be noted:

FIRST: Regarding the defenselessness generated for IBERDROLA as a consequence of the failure to agree on the accumulation of procedures EXP202305587 and EXP202205206

IBERDROLA reiterates its position regarding the Agreement of Initiation concerning its request for the accumulation of both files, indicating furthermore that, regardless of the fact that Article 57 of the LPACAP indicates a "may," the power granted must be considered in any case enforceable by the Administration when the non-accumulated processing of the procedures may negatively affect the rights of those involved in them, insisting that the non-accumulation infringes upon its right to defense. In this regard, it should be noted, first of all, that a response was already provided in the proposal for resolution regarding the request for the accumulation of the two referenced files, a response that is fully transcribed in Legal Basis III of this Resolution, to which reference should be made.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

55/99

totality. Therefore, while it is true that it is within the Administration's power to proceed with the accumulation or not, it is also true that the reasons and arguments were presented regarding why it was not appropriate to accumulate both sanctioning procedures.

Furthermore, IBERDROLA argues that the lack of accumulation leaves it defenseless, as it believes that its access to the information that the AEPD has provided to consider two alleged infringements has been limited to those elements that the AEPD deemed appropriate to incorporate into the present file, without being able to have a complete view of the facts or, consequently, of the reasons that lead the AEPD to impose such sanctions.

In response, it should be noted that it is unclear what information or circumstances IBERDROLA believes it is unaware of, as it has been fully aware of the facts and all circumstances related to them at all times. It has also been aware at all times of the infringements attributed to it due to such facts and of the sanctions that may arise from them, and it has been able to argue and present any documentation it deemed relevant throughout the present sanctioning procedure.

Therefore, the requested lack of accumulation does not leave it defenseless nor does it negatively affect any of its procedural rights.

Regarding the other arguments raised by IBERDROLA to demand accumulation, as these are a repetition of those presented against the Initiation Agreement, it is appropriate to refer to the response given by this Agency, which appears, as noted, transcribed in the Legal Basis III of this Resolution.

SECOND: Regarding the prior acts of the AEPD and the violation of the principles of good faith, legitimate trust, and legal certainty.

IBERDROLA insists again that the letter dated April 18, 2022, addressed to I-DE from the Technological Innovation Division of this Agency is decisive and that this prevents or should have prevented any subsequent investigation into the personal data breach suffered, which also violates the principles of good faith, legitimate trust, and legal certainty.

Firstly, it was already indicated to IBERDROLA in response to the allegations regarding the Initiation Agreement that the aforementioned communication from the Technological Innovation Division of this Agency was directed solely to I-DE and related to the notifications made by it to the aforementioned Division as a result of a personal data breach suffered by it.

Therefore, said letter in no way referred to the personal data breach suffered by IBERCLI and CURENERGIA and notified to this Agency by these companies, for which the present sanctioning procedure is being processed against IBERDROLA as the data processor of the same, no matter how much it now attempts to extend it to this file. It is for this reason that this letter is not included in the present sanctioning procedure, and thus it is also not appropriate to accept, as IBERDROLA claims, that this absence has caused it defenselessness. Nonetheless, the same

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

56/99

was submitted by IBERDROLA along with its written allegations to the Initiation Agreement, and in the resolution proposal, a response was provided addressing the erroneous interpretation that IBERDROLA had regarding the content and nature of the aforementioned document.

IBERDROLA also states the following:

“However, it is the Proposal for Resolution itself that highlights the close connection between the document addressed to i-DE (the omission of which from the present file would only generate defenselessness for my client) and the present procedure when it subsequently adds that ‘since the personal data breach notified by i-DE resulted in the breach suffered by IBERCLI and CURENERGÍA, we proceed to respond to the erroneous interpretation made by IBERDROLA regarding the aforementioned document.’

In this way, the AEPD expressly acknowledges that, even though the document was addressed to i-DE, there exists an intimate and indissoluble relationship between both procedures, given that the breach attributed to my client arises directly from the vulnerability produced in the GEA application. Thus, it is evident that if the AEPD considered the clarifications made by i-DE in the notification related to the breach that gives rise to the present file to be sufficient, and it is clear that without said breach the one now analyzed would not have occurred, the consideration of the cause as not susceptible to prior investigation must result in the sole consequence of archiving the procedure referred to, which is merely an effect of that cause previously considered sufficiently justified.”

In this regard, it is noted that what has been indicated is that from the same incident (cyberattack) two different personal data breaches arose. One affecting personal data of customers of i-DE due to a vulnerability in its web application. And another affecting customers of IBERCLI and CURENERGÍA because all three companies store the personal data of their respective clients in a database managed by IBERDROLA as the data processor and due to a vulnerability in the logical separation in said database.

Notwithstanding the above, just as a response was provided in the Proposal for Resolution regarding IBERDROLA's arguments concerning the communication of April 18, 2022, and since it continues to believe that this document affects the present sanctioning procedure - which has already been indicated is not the case - a response is provided below regarding the new arguments put forward by IBERDROLA in relation to the same.

Thus, IBERDROLA indicates that one of the functions of the Technological Innovation Division of this Agency is to “analyze and classify security breaches and, where appropriate, propose to the Presidency the initiation of an investigation when it perceives indications of the commission of an infringement” (Article 31 e) of the AEPD Statute).

IBERDROLA adds that the aforementioned document is signed by the “AEPD,” which implies that it

should be understood as signed by the Director, since the “legal representation and...

57/99

The "institutional" representation of the Agency corresponds solely and exclusively to the Director, as established in Article 13.1b) of the Statute of the AEPD.

From this, IBERDROLA concludes that, having analyzed the information communicated by it regarding the security breach, the Division of Technological Innovation understood that it was not appropriate to elevate any type of motivated proposal to the Director of the AEPD concerning the same, as it did not consider that the provisions of the GDPR had been infringed. This led to the Agency being notified of the decision not to carry out any action related to the aforementioned breach.

In this regard, it is first necessary to recall that this issue was already addressed in the Proposal for Resolution, and it is responded to in Legal Basis IV of the present Resolution, to which reference should be made.

On the other hand, it cannot be admitted or understood, even indirectly, that the aforementioned document in question is signed by the Director of this Agency, as her signature does not appear expressly, no matter how much IBERDROLA wishes to artificially presume that the signature comes from that body by holding the representation of the AEPD. No generic signature of the AEPD or any of the bodies in which it is structured, nor the signature of any of the individuals holding positions within them, can replace the signature of the Director when exercising the competencies attributed to her by both Law and the Statute of the AEPD. Furthermore, the delegation of signature in these cases must be direct and express, and must be recorded in the administrative act that is signed by delegation to ensure and safeguard that the decision has been adopted by a competent body.

In this sense, the Statute of the Spanish Agency for Data Protection, approved by Royal Decree 389/2021, of June 1 (hereinafter the Statute), expressly establishes that:

“1. The Presidency of the Spanish Agency for Data Protection is responsible for:

(...)

d) Issuing the resolutions and guidelines required for the exercise of the Agency's functions, particularly those arising from the exercise of the competencies provided for in Article 57 of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, and from the exercise of the investigative powers and corrective powers provided for in Article 58 of the aforementioned Regulation.” (the underlining is ours)

On the other hand, Article 27 of the Statute establishes the competencies of the General Subdirectorate of Data Inspection of the AEPD:

“1. The General Subdirectorate of Data Inspection is the administrative body, dependent on the Presidency of the Spanish Agency for Data Protection, that develops the competencies provided for in Article 57.1, letters f), g), h), i) and u) of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, and carries out the inspection and instruction functions necessary for the exercise of the investigative powers established in Article 58.1, letters a), b), d), e) and f).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

58/99

and the corrective powers provided for in Article 58.2, letters a), b), c), d), f), g), i) and j), both of the aforementioned Regulation. (the underlining is ours)

2. In order to fulfill the tasks established in the previous section, the General Subdirectorate of Data Inspection has the following functions:

a) The permanent supervision of compliance with Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, of Organic Law 3/2018, of December 5, and the provisions that develop it, by the controllers and processors of the data.

b) The exercise of the investigative powers defined in Article 51 of Organic Law 3/2018, of December 5.

(...)

d) The processing of procedures in the event of a possible violation of data protection regulations in

accordance with the provisions of Title VIII of Organic Law 3/2018, of December 5, including citizens' complaints for lack of attention to their requests for the exercise of the rights contemplated in Articles 15 to 22 of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016. It is the duty of the General Subdirectorate of Data Inspection to inform the complainant about the course and the outcome of the complaint submitted to the Spanish Agency for Data Protection, in accordance with the provisions of Article 77.2 of the aforementioned Regulation.

(...)

e) The evaluation of the admissibility of the complaints submitted to the Spanish Agency for Data Protection, and the proposal to the Presidency of a decision on the admission or inadmissibility of the complaint, in accordance with the provisions of Article 65 of Organic Law 3/2018, of December 5.

(...)

h) The carrying out of preliminary investigative actions agreed upon by the Presidency on its own initiative, following a complaint, or at the request of another body or control authority, in order to achieve a better determination of the facts and circumstances that justify the processing of the procedure, as provided for in Article 67 of Organic Law 3/2018, of December 5." (the underlining is ours)

Therefore, regarding the Division of Technological Innovation of the AEPD, which in accordance with the Statute has, among its functions, the task of "analyzing and classifying security breaches and, where appropriate, proposing to the Presidency the initiation of an investigation when it perceives indications of the commission of an infringement" (Article 31 e) of the AEPD Statute), this does not mean that it is the only and exclusive way by which this Agency can initiate investigative actions. Thus, this investigative power that the AEPD has, as reflected in the described regulations, is carried out by the General Subdirectorate of Data Inspection, which can initiate investigative actions either ex officio, by order of the Director, or as a result of the admission of complaints submitted to the AEPD.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

59/99

The Division of Technological Innovation, after analyzing the documentation provided by I-DE (which does not cover all the circumstances of the incident), has indicated that it does not foresee the initiation of other actions, and it does not mean that it considers the provisions of the GDPR to have been infringed or that a decision has been made not to carry out any action related to the aforementioned breach. The Division of Technological Innovation did not make a decision; it merely informed I-DE of a forecast, which does not prevent other circumstances from being taken into account, such as the filing of complaints by those affected by the breach, which may advise deviating from this forecast.

Therefore, the aforementioned document does not have the decisive and resolute character that IBERDROLA now seeks, neither by its content nor by its form, and this does not hinder or prevent in any way the investigative power that the AEPD has and its exercise through the inspection and investigation functions assigned to the General Subdirectorate of Data Inspection. Above all, after the filing of complaints by affected individuals, which the LOPDGDD obliges to process.

Thus, Article 65 of the LOPDGDD, relating to the "Admission of complaints for processing," establishes that:

1. When a complaint is presented to the Spanish Agency for Data Protection, it must evaluate its admissibility for processing, in accordance with the provisions of this article.
2. The Spanish Agency for Data Protection will inadmit complaints presented when they do not concern issues of personal data protection, are manifestly unfounded, are abusive, or do not provide reasonable indications of the existence of an infringement.

Therefore, once complaints are filed with the AEPD, it is obliged to analyze their admissibility beforehand, being able to inadmit them only in the cases of section 2 of Article 65 transcribed, which did not occur in the case at hand.

Thus, once admitted for processing, preliminary investigative actions were initiated precisely to ascertain the facts and circumstances that occurred and whether a possible violation of data protection

regulations could be derived from them, as permitted and empowered by Articles 64 and 66 of the LOPDGDD, which were already transcribed in the response to the allegations to the Initiation Agreement and which, for the sake of clarity, are reiterated:

Article 64. Method of initiation of the procedure and duration.

1. When the procedure refers exclusively to the failure to address a request for the exercise of the rights established in Articles 15 to 22 of Regulation (EU) 2016/679, it will be initiated by an agreement of admission for processing, which will be adopted in accordance with the provisions of Article 65 of this organic law.

In this case, the deadline for resolving the procedure will be six months from the date on which the agreement of admission was notified to the complainant.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

60/99

procedure. Once this period has elapsed, the interested party may consider their claim to be accepted.

2. When the procedure aims to determine the possible existence of an infringement of the provisions of Regulation (EU) 2016/679 and this organic law, it will be initiated by an initiation agreement adopted on its own initiative or as a result of a claim.

If the procedure is based on a claim made to the Spanish Data Protection Agency, prior to this, it will decide on its admissibility in accordance with the provisions of Article 65 of this organic law.

When the rules established in Article 60 of Regulation (EU) 2016/679 are applicable, the procedure will be initiated by the adoption of the draft initiation agreement for sanctioning procedures, of which the interested party will be formally informed for the purposes provided in Article 75 of this organic law.

Once the claim is admitted for processing, as well as in cases where the Spanish Data Protection Agency acts on its own initiative, prior to the initiation agreement, there may be a phase of preliminary investigative actions, which will be governed by the provisions of Article 67 of this organic law. (the underlining is ours)

Article 67. Preliminary investigative actions.

1. Before the adoption of the initiation agreement for the procedure, and once the claim has been admitted for processing, if any, the Spanish Data Protection Agency may carry out preliminary investigative actions in order to achieve a better determination of the facts and circumstances that justify the processing of the procedure.

The Spanish Data Protection Agency will act in any case when the investigation of treatments involving massive traffic of personal data is necessary.

2. The preliminary investigative actions will be subject to the provisions of Section 2 of Chapter I of Title VII of this organic law and may not last longer than twelve months from the date of the admission agreement or from the date of the agreement deciding its initiation when the Spanish Data Protection Agency acts on its own initiative or as a result of the communication sent to it by the supervisory authority of another Member State of the European Union, in accordance with Article 64.3 of this organic law. (the underlining is ours)

Therefore, it is reiterated that from this regulation it is not inferred in any way that the AEPD must justify in the manner required by IBERDROLA the initiation of preliminary actions in the sense that there must be something new or some new circumstance or that the claims must have provided new and different circumstances regarding the documentation provided by I-DE in its notification of C/

Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

61/99

breach to this Agency, as this is not required by the indicated regulations, in addition to the fact that it cannot be expected that those affected provide anything new, aside from knowing that the confidentiality of their personal data has been violated by a cyberattack of which they are unaware of

the circumstances.

The preliminary investigative actions are precisely carried out to clarify the facts and circumstances of what has occurred, gathering more information in order to determine the existence of a possible infringement of the data protection regulations. In this sense, the initiation of preliminary investigations and their execution, a power of the AEPD with or without complaints, does not prejudice anything, but allows for the collection of the necessary information to determine whether there are indications of an infringement or not. Even after such an investigation, it may be that the proceedings are archived because, based on the information gathered, it is understood that there are no indications of an infringement. This has not happened in the present case.

What the reflected regulations do indicate is that, after the submission of complaints, this Agency must decide whether to admit them for processing or not, having ultimately decided on their admission through, this time, an Agreement of admission for processing, signed by the Director of the Agency on May 9, 2022. And, as indicated in article 67.2 of the LOPDGDD referenced, the AEPD may carry out preliminary investigative actions in order to achieve a better determination of the facts and circumstances. It is a power that is attributed to it by the GDPR and by the LOPDGDD.

Furthermore, and to further elaborate on everything, as indicated, even in the event that there had been no complaints, the provision of the Division of Technological Innovation would not have been an obstacle or hindrance for the exercise, ex officio, of the investigative powers that the AEPD has in accordance with the cited article 64.2 which states that "Once the complaint is admitted for processing, as well as in cases where the Spanish Data Protection Agency acts on its own initiative, prior to the agreement to initiate, there may be a phase of preliminary investigative actions..."

Therefore, the present sanctioning procedure has not been initiated due to the content or any new information provided in the complaints, but rather due to the information and documentation obtained after the period of preliminary investigative actions, as possible violations of the data protection regulations can be inferred from it.

THIRD: On the arguments put forth by the Proposal for Resolution to consider that the principle of non bis in idem does not apply.

IBERDROLA again indicates that the principle of non bis in idem has been violated in the imposition of the two infringements, as it understands that the AEPD is not judging the violation of article 5.1.f) of the GDPR for a reason different from that derived from what it considers to be inadequate security of personal data, but solely and exclusively for that reason.

In this regard, the Judgment of the National Court of July 23, 2021 (rec. 1/2017) was already mentioned, which states,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

62/99

"(...) According to the legislation and jurisprudence presented, the principle of non bis in idem prevents punishing the same individual twice for the same act based on the same grounds, understood as the same legal interest protected by the sanctioning norms in question. Indeed, when there is a triple identity of subject, act, and grounds, the accumulation of sanctions creates a penalty that is foreign to the proportionality assessment carried out by the legislator and materializes the imposition of a sanction not legally provided for, which also violates the principle of proportionality.

However, for "bis in idem" to be applicable, there must be a triple identity among the compared terms: objective (same facts), subjective (against the same subjects), and causal (for the same grounds or reason for punishment):

a) The subjective identity implies that the affected subject must be the same, regardless of the nature or judicial or administrative authority that judges and irrespective of who the accuser or specific body that has resolved the matter is, whether judged alone or in conjunction with others affected.

b) The factual identity implies that the judged facts must be the same, and excludes cases of real concurrence of infractions where there is not a single unlawful act but several.

c) The identity of grounds or causal identity implies that the sanctioning measures cannot coexist if

they respond to the same nature, that is, if they share the same teleological foundation, which occurs between penal and administrative sanctions, but not between punitive and merely coercive measures.” Taking into account what has been previously stated, in the sanctioning procedure, the principle of non bis in idem has not been violated, since, although broadly understood, the facts are detected as a consequence of a personal data breach, the infringement of Article 5.1.f) of the GDPR is specified in a clear loss of confidentiality that affected certain clients, while the infringement of Article 32 of the GDPR is reduced to the deficiency of the security measures (only security) detected, which are present independently of the personal data breach. In fact, if these security measures that IBERDROLA had in place had been detected by the AEPD without the loss of confidentiality occurring, it would only have been sanctioned under Article 32 of the GDPR.

As we have indicated, Article 5.1.f) of the GDPR sanctions a loss of confidentiality and availability, while Article 32 of the GDPR addresses the deficiency of the security measures implemented by the data controller. Deficient security measures, we add, that infringe the GDPR, regardless of whether or not a personal data breach has occurred.

Article 32 of the GDPR is violated regardless of whether or not a personal data breach occurs. That is to say, it is infringed by not having appropriate measures to ensure adequate security in the processing of data without it being necessary or essential for a personal data security breach to occur, which, in its case, may affect either the confidentiality of the data, or only the availability, or only the integrity, or some or all of them.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
63/99

Another matter is that the deficiency in security measures is manifested, in the specific case, during a violation of personal data security (breach of confidentiality in this case), as has occurred in the present case.

On the other hand, Article 5.1(f) of the GDPR is violated when there is a loss of confidentiality or integrity of personal data, which may or may not occur due to the absence or deficiency of security measures. This principle merely determines the means through which the maintenance of confidentiality, integrity, or availability can be achieved when it explicitly states "through the application of appropriate technical and organizational measures," which are not strictly security measures. It is also emphasized again that Article 5.1(f) of the GDPR is one of the principles related to processing. The principles related to processing are, on one hand, the starting point and the closing clause of the legal framework for data protection, constituting true guiding rules of the system with an intense expansive force; on the other hand, having a high level of specificity, they are mandatory norms that can be infringed.

The breach of confidentiality attributed to I-DE is due to non-compliance with the obligation imposed in Article 5.1(f) to process data in such a way as to ensure an adequate level of security, including protection against unauthorized or unlawful processing, through the application of appropriate technical or organizational measures.

Finally, it should be added that, regarding the alleged breach of the principle of non bis in idem, a response to this allegation was already provided in the Proposal for Resolution, in which it is extensively argued that there is no existence of the triple identity of facts, subject, and basis, as required by jurisprudence, a response that is fully transcribed in section Three of the Legal Basis IV of this Resolution and to which reference should be made.

Lastly, concerning what IBERDROLA has alleged regarding the assertion that the imposition of the infringement of Article 5.1(f) requires a result-oriented obligation, which is contrary to the Judgment of February 15, 2022 (cassation appeal 7359/2020), which states that the obligation imposed by personal data protection regulations to adopt technical and organizational measures is an obligation of means and not of results, it is noted that what was analyzed in that Judgment is the compliance with technical and organizational measures in the sense of whether they are adequate to ensure the security of

processing, that is, we would not be in the realm of compliance with Article 5.1(f), but in the realm of compliance with Article 32 of the GDPR as it pertains to security measures. Therefore, the argument presented by IBERDROLA and the analysis thereof to be conducted must refer exclusively to the infringement of Article 32 of the GDPR, which will be developed in section Five of this Legal Basis concerning the infringement of Article 32.

FOURTH: On the application of the principles of sanctioning law to the activity of the AEPD and the concurrence of a medial competition.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
64/99

IBERDROLA again claims that, in the event that the existence of bis in idem is not recognized, at least one of the infringements would be subsumed and embedded in the other, since the imputation of the infringement of Article 5.1.f) of the GDPR is due to the fact that the processing has not been carried out, in the opinion of the AEPD, in compliance with the necessary security measures. IBERDROLA therefore understands that there is an absolute link between the alleged absence of adequate security measures and the breach of the principle of confidentiality. That is to say, it is the alleged insufficiency of the security measures that directly leads to the violation of Article 32 and the violation of 5.1.f).

Therefore, there is a clear case of medial concurrence, as the two infringements attributed cannot be committed one without the other.

Subsequently, IBERDROLA argues the reasons why it considers that Article 29 of the LRJSP is applicable and that, by not applying it, the AEPD is implicitly repealing, in matters of data protection, all the guarantees of the sanctioning regime established by the Constitutional Court.

In this regard, since this allegation has already been made in response to the Initiation Agreement and is addressed in section Third of Legal Basis IV, it is appropriate to refer to it in its entirety.

On the other hand, regarding the mention made by the AEPD concerning the non-applicability of Article 29 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (hereinafter, "LRJSP"), IBERDROLA brings up Royal Decree 389/2021, of June 1, which approves the Statute of the Spanish Agency for Data Protection, in which Article 3 establishes that the AEPD is governed by the provisions of the GDPR, and subsidiarily, by the LRJSP. IBERDROLA understands that the above implies that, in relation to all matters not expressly regulated in the GDPR or the LOPDGDD, the provisions in the LRJSP will apply, as is the case with the infringement competitions provided for in Article 29 of the LRJSP in relation to the principle of proportionality as a principle of the sanctioning power.

In this regard, it is noted that Article 3.2 of the aforementioned Statute of the AEPD establishes the following:

2. Subsidiarily, as far as it is compatible with its full independence, it will be governed by Law 40/2015, of October 1, on the Legal Regime of the Public Sector, in particular the provisions for autonomous bodies; by Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations; by Law 47/2003, of November 26, on General Budgetary Matters; by Law 9/2017, of November 8, on Public Sector Contracts, by which the Directives of the European Parliament and of the Council 2014/23/EU and 2014/24/EU, of February 26, 2014, are transposed into the Spanish legal system; by Law 33/2003, of November 3, on the Heritage of Public Administrations, as well as the rest of the general and special administrative law norms that are applicable to it. In the absence of an administrative norm, common law will apply.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
65/99

Therefore, what is being indicated is that the legal regime of the Public Sector is applied subsidiarily, but in relation to its consideration as a public body belonging to the General Administration of the

State, that is, to considerations such as its composition, organization, structure, etc.

On its part, Article 3.3 of the Statute of the AEPD states the following:

3. The procedures processed by the Spanish Agency for Data Protection will be governed by the provisions of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights, by the regulatory provisions issued in its development and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures.

Therefore, in the procedures processed by it, including the sanctioning procedure, neither the LRJSP nor the LPAC is applied subsidiarily, but it declares that the procedures processed by the AEPD will be governed by the RGPD and the LOPDGDD. And subsidiarily (not supplementarily) by the rules on administrative procedures.

In this regard, it is emphasized that there is no supplementary application of the aforementioned provision, since there is no legal gap regarding the application of the medial contest provided for in Article 29 of the LRJSP. Neither the RGPD allows nor the LOPDGDD provides for the supplementary application of the provisions of Article 29 of the LRJSP.

In Title VIII of the LOPDGDD relating to "Procedures in case of possible violation of data protection regulations," Article 63 that opens the Title states that "The procedures processed by the Spanish Agency for Data Protection will be governed by the provisions of Regulation (EU) 2016/679, in this organic law, by the regulatory provisions issued in its development and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures." Although there is a reference to the LPACAP, there is absolutely no establishment of a subsidiary application regarding the LRJSP, which does not contain any provision related to any administrative procedure in its wording.

Just as the AEPD is not applying the aggravating and mitigating factors provided in the same Article 29 of the LRJSP, since the RGPD establishes its own, therefore, there is no legal gap or subsidiary application of the same, nor can the section relating to the medial contest be applied for the same reasons.

As already indicated, the application of rules foreign to the RGPD regarding the determination of fines in each of the Member States applying their national law, whether due to aggravating or mitigating circumstances not provided for in the RGPD -or in the LOPDGDD in the Spanish case-, or due to the application of a medial contest different from that provided in the RGPD, would undermine the effectiveness of the system, losing its meaning, its teleological purpose, resulting in fines imposed for different infractions ceasing to be effective, proportionate, and dissuasive. And in this way, it would also deprive the interested parties of the effective guarantee of their rights and freedoms, weakening the uniform application of the RGPD. The mechanisms for protecting the rights and freedoms of citizens would be diminished and it would be contrary to the spirit of the RGPD.

It should be clarified, beforehand, that subsidiarity refers to cases in which a specific case is not regulated in a certain norm, a legal gap, leading to the application of another legal norm that regulates such a situation, provided that it does not conflict with the legal system.

While subsidiarity refers to a competition of norms, which means that for a certain case two or more norms may be applicable, so that the subsidiary norm yields in favor of the main one.

Well, having examined both supplementarity and subsidiarity, it is concluded that Article 29 of the LRJSP does not apply, but rather Article 83 of the RGPD in relation to the principle of proportionality.

This is so because:

- The principle of proportionality applies to the sanctioning procedure.
- The principle of proportionality is fully regulated in Article 83 of the RGPD.
- There is no legal gap.
- Neither the RGPD nor the LOPDGDD refer to the application, due to the existence of a legal gap, of Article 29 of the LRJSP.
- In the procedures processed by the AEPD, for the administrative procedures processed, the subsidiary application of the general rules on administrative procedures is provided.
- In the procedures processed by the AEPD, for the administrative procedures processed and not in relation to the principles of the sanctioning procedure, the LOPDGDD does not establish a subsidiary

application of the LRJSP.

Therefore, there is neither supplementarity nor subsidiarity that would make Article 29 of the LRJSP applicable.

Regarding the fact that, as indicated by IBERDROLA, the Agency itself has previously considered the applicability of said Article 29 considering the existence of cases of medial contest, as in its Resolution of April 23, 2021, issued in procedure PS/00240/2019, it should be noted that the Administration can depart from what was previously resolved. Thus, Article 35 of the LPACAP establishes that:

1. They shall be motivated, with a succinct reference to facts and legal grounds:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

67/99

c) Acts that deviate from the criteria followed in previous proceedings or from the opinions of advisory bodies.

Therefore, it is legitimate for the Administration to depart from the criteria followed in previous proceedings, as long as such change is justified, which is the case here. Thus, in addition to what has just been argued in this very section, it is appropriate to recall once again that this allegation was already made against the Initiation Agreement, regarding the concurrent infringement, and a response was provided justifying and arguing why the existence of concurrent infringement is not considered, and furthermore, the non-applicability of Article 29 of the LRJSP is justified. Therefore, it is appropriate to refer to the arguments presented, which are transcribed in Section Three of the Legal Basis IV of this Resolution.

Thus, once it has been argued and justified not only that the existence of concurrent infringements is not considered, as well as the reasons why Article 29 of the LRJSP is deemed inapplicable, the change of criteria is legitimate and not contrary to law.

In this regard, the Judgment of March 12, 2018, from the High Court of Justice of Madrid, Administrative Litigation Chamber, Section 4 (Rec. 761/2017), states, on the occasion of the review of a sanctioning procedure, that:

"(...) the Administration can separate itself from what was previously resolved by justifying the change (art. 35.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations). As the Supreme Court points out in its Order of December 4, 1998, '... for the doctrine of the Administration's own acts to apply, it is fundamentally necessary that a first body of the Administration has issued a first declarative act of rights and then that the second revokes the decision made in the first', and this circumstance does not occur in this case because the present administrative act of tax settlement does not revoke any decision made in a previous act related to the same tax concept nor is there an express declarative act that is now being modified.

For these purposes, it is appropriate to distinguish between the effectiveness of the Administration's own acts and the binding nature of the Administration to the interpretative precedents applied in previous situations since, in the case being questioned, and using the words of the Supreme Court (judgment of February 25, 2000), one cannot speak of "own act but at most a change of criteria and interpretation, which is perfectly valid." Likewise, the STS of June 27, 2000 refers:

"... the principle of acting against one's own acts could not be taken to extremes that would obstruct the legality of a particular action, merely due to the existence of another previous act of a different nature even if it was not supported by legality, just as equality can only exist within the realm of legality, as is sufficiently known, under penalty of consolidating forever illegal or non-compliant resolutions, irreversible and impossible to modify later."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

68/99

In the same vein, the High Court has expressed itself in other Judgments. Thus, in the judgment of

February 1, 1999, it declares that "this principle cannot be invoked to create, maintain, or extend in the field of Public Law, situations contrary to the legal order, or when the preceding act contradicts the purpose or interest protected by a legal norm that, by its nature, is not susceptible to shelter a discretionary action of the Administration that implies the recognition of rights and/or obligations that stem from its own acts. In other words, the doctrine of own acts without the limitation just exposed could introduce into the realm of Public Law relations the principle of autonomy of will as an organizing method of matters regulated by imperative norms, in which the public interest safeguarded by the principle of legality prevails; a principle that would be violated if validity were given to an action of the Administration contrary to the legal order solely because it has been decided by the Administration or because it responds to a precedent of this. (...) or, stated in other terms, it cannot be said that the trust placed in an act or precedent that is contrary to the imperative norm is legitimate" (the emphasis is ours).

Likewise, and to further elaborate, this criterion of understanding that Article 29 LRJSP is not applicable is not new as it has been applied in sanctioning files prior to the present one. By way of example, PS/00020/2023 and PS/00667/2023 are noted.

Finally, IBERDROLA argues that the application of Article 29 is also a possibility recognized by Guidelines 4/2022, on the calculation of administrative fines under the GDPR, where the criteria that the administrative authority must follow to evaluate, prior to the imposition of the sanction, the possible concurrence of these are expressly stipulated.

In this regard, it is noted that, concerning the citation of Guidelines 04/2022 of the CEPD on the calculation of administrative fines in accordance with the GDPR, in its version 2.1, adopted on May 24, 2023, reference is made in section 22 to three types of concurrence, namely, of infringement, unity of action, and plurality of actions: "When examining the analysis of the traditions of the Member States regarding concurrency rules, as indicated in the jurisprudence of the CJEU, and taking into account the different areas of application and legal consequences, these principles can be grouped approximately into the following three categories: - Concurrence of infringements (chapter 3.1.1), - Unity of action (chapter 3.1.2), - Plurality of actions (chapter 3.2).

In cases of concurrence of infringements, the provision established in this regard is contained in Article 83.3 of the GDPR, which establishes a quantitative limit in these cases of concurrence: "If a controller or a processor intentionally or negligently violates various provisions of this Regulation for the same processing operations or linked operations, the total amount of the administrative fine shall not exceed the amount provided for the most serious infringements."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

69/99

Likewise, at this moment we must recall that the severity of infringements of the GDPR is determined according to the rules established in this regulation and not in the LOPDGDD. The classification of infringements is regulated in Article 83, paragraphs 4, 5, and 6 of the GDPR, while the qualification of infringements as very serious, serious, or minor solely for the purposes of prescription is provided for in Articles 72, 73, and 74 of the LOPDGDD.

Finally, and no less important, the AEPD does not sanction for the same offense, as IBERDROLA claims, but it has been established through proven facts not rebutted by IBERDROLA, the commission of two differentiated infringements, classified in a differentiated manner, and there being no medial concurrence in the specific case.

For all the above, this allegation is dismissed.

FIFTH: On the non-existence of a violation by I-DE of Article 32 of the GDPR

IBERDROLA again indicates that it had carried out a risk analysis that the processing of data could generate on the rights and freedoms of the affected parties, as well as implemented security measures that allowed mitigating the aforementioned risks.

In response, it should be indicated that the risk analysis of the processing activity affected by the

incident does not show any measures to be adopted to mitigate the supposed detected risks.

Thus, in response to the request made by this Agency during the previous investigation proceedings, for a copy of the risk analyses regarding the rights and freedoms of individuals carried out prior to the incident and in relation to the processing activity affected by the personal data breach, both IBERCLI and CURENERGÍA provided the same document and indicate that it is the scheme followed within the Iberdrola Group for the assessment of risk in the processing of personal data and that it is carried out according to the same:

(...)

Likewise, both companies attached an explanatory document of the logic followed for the calculation of the level of risk according to this methodology, called "Logic for Calculating Risk Level":

(...)

(...)

They explain that this methodology is implemented in an automated manner in the corporate tool for recording processing activities, so that in the very registration process, the level of risk of the processing is determined.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

70/99

As can be seen, the cited document details certain threats or circumstances— which are transferred to the Register of Processing Activities, to the corresponding activity—such as "vulnerable groups," "access to personal data by more than 10 people," "international transfers," "large-scale processing," and "profiling with legal effects." These circumstances are established as questions, and depending on whether the answer is "yes" or "no," a result is applied.

Thus, the application of this methodology in relation to the affected processing activity "(...)" ("...") for which they are responsible, in relation to their respective clients IBERCLI and CURENERGIA, resulted in a MEDIUM risk level.

Therefore, several of these questions appear in the Register of Processing Activities for the activity affected by the personal data breach, where the answers are "Yes" or "No," indicating a "Medium" risk, but nothing more. That is to say, no measures are indicated that should be adopted to mitigate that medium risk, nor whether it is an inherent risk or a residual risk.

Furthermore, when requested by IBERDROLA to provide the risk analyses and, where applicable, the DPIAs, regarding the processing it carries out as a data processor and in relation to the processing activities affected by the breach, it responds in its reply (submitted on 24/01/2023 Registration Number: REGAGE23e00004670187) that:

"The Iberdrola Group has adopted a methodology for risk analysis of personal data processing that is implemented in an automated manner within the corporate tool for registering processing activities, so that the risk level of the processing is determined in the registration process itself.

In the case of the processing for which IBERDROLA acts as a data processor, the methodology involves conducting a risk analysis in relation to each of the processing activities for which my client holds that status, so that this analysis is developed by the entity responsible for the processing in collaboration with my represented party.

For this reason, the risk analysis related to the specific processing activities (...) is incorporated into the Registers of Processing Activities of i-DE and those of IBERCLI and CURENERGIA, and their results have been communicated to my client. According to the information provided by these entities, the result of this analysis is included in the responses provided in this procedure to the information requests made to them."

Additionally, at the request of this Agency during the preliminary investigation phase, IBERDROLA provided (registration number: REGAGE23e00004673128) the Register of Processing Activities corresponding to the processing "Support and Maintenance of IT Infrastructures" (activity "RET_IT_001") and "Application Development (SWF)" (activity "RET_IT_011") carried out by IBERDROLA in its capacity as a data processor regarding various processing activities of the Iberdrola

Group companies, among which are those affected by the breach.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
71/99

security breach. Analyzing said Register, none of the questions or circumstances referred to in the documents previously reflected and indicated for the entire Iberdrola Group as a methodology for risk analysis of personal data processing have been transferred to it, which is implemented in an automated manner in the corporate tool for recording processing activities, so that in the registration process itself, the level of risk of the processing is determined.

Therefore, IBERDROLA has not demonstrated that it has conducted a risk analysis regarding the processing activities mentioned above and that it carries out in its capacity as a data processor, nor has it substantiated what it claims regarding the implementation of security measures that would mitigate those risks. It has also not demonstrated that it has assessed the inherent risks arising from its participation as a processor in other processing activities, nor that the measures adopted are adequate to mitigate them. In particular, it has not demonstrated that it has evaluated the inherent risks of the processing it performs, which consists of storing personal data from different data controllers (different companies) in the same database, in which, moreover, exceptionally (as it indicates) it stores personal data in the same Table with only a logical separation, which means that it has also not demonstrated the adoption of security measures that would allow for the mitigation of those unassessed risks. Furthermore, upon analyzing the methodology provided by both IBERCLI and CURENERGÍA, which they (IBERDROLA as well) state is applied to the entire Iberdrola Group for conducting the risk analysis, as well as the documentation provided, especially the respective Records of Processing Activities, it is not reflected that such analyses are focused on the risks of variable probability and severity that the processing may entail for the "rights and freedoms of natural persons," such as physical, material, or immaterial damages, particularly issues of discrimination, identity theft, fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; in cases where data subjects are deprived of their rights and freedoms or prevented from exercising control over their personal data; in cases where personal aspects are evaluated, particularly the analysis or prediction of aspects related to work performance, economic situation, health, personal preferences or interests, reliability or behavior, situation or movements, in order to create or use personal profiles; in cases where personal data of vulnerable individuals, particularly children, are processed; or in cases where the processing involves a large amount of personal data and affects a large number of data subjects, etc., all in accordance with Recital 75 of the GDPR.

For its part, Article 28.2 of the LOPDGDD states that "For the adoption of the measures referred to in the previous paragraph, data controllers and processors shall take into account, in particular, the greater risks that could arise in the following cases:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
72/99

a) When the processing could generate situations of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic, moral, or social harm to the affected individuals.

b) When the processing could deprive the affected individuals of their rights and freedoms or could prevent them from exercising control over their personal data (,,).

Furthermore, as explained in the guide "Risk Management and Impact Assessment in Personal Data Processing" by the AEPD, "The GDPR establishes the obligation to manage the risk that processing poses to the rights and freedoms of individuals. This risk arises both from the very existence of the

processing and from its technical and organizational dimensions. The risk arises from both automated data processing and manual processing, from human elements and from the resources involved. The risk arises from the purposes of the processing and its nature, as well as from its scope and the context in which it takes place."

However, as indicated, these risks have not been assessed. The damages to individuals, whether material or immaterial, have not been evaluated, or at least it is not evidenced that such an evaluation has been made, thus lacking a risk analysis focused on the protection of the rights and freedoms of the data subjects. Furthermore, in the risk analysis carried out, it is also not indicated what security measures should be adopted to mitigate the identified "Medium" risk.

For the reasons stated, as previously noted, IBERDROLA has not substantiated its claim that it "had carried out an analysis of the risks that the processing of the data could generate on the rights and freedoms of the data subjects, as well as implemented security measures that allowed mitigating the aforementioned risks."

On another note, IBERDROLA claims that the statements made by the AEPD in the Proposal for Resolution highlight the existence of an absolute causal relationship between the vulnerability attributed to IBERDROLA and that produced in the GEA application. It transcribes the following from the Proposal:

"(...) Therefore, it was not adequate or was insufficient, which constitutes a violation of Article 32, as it reflects a lack or insufficiency of appropriate measures to ensure adequate security, according to the risk, in the processing of personal data."

In response, it is emphasized that what has been indicated is that what was revealed by the cyberattack and by IBERDROLA's statements regarding how the database it manages operates, the existing logical separation in the database was inadequate as it allowed, by modifying a parameter in an application of one of the companies, access to personal data of clients of other companies for which there is no authorization for such access. That is to say, it was possible to "bypass" or overlook that logical separation.

In this regard, it is worth recalling that according to what IBERDROLA indicated, (...)

(...)

(...):

- (...)

Therefore, there existed an inadequate logical separation of the personal data of clients from different companies stored in the same Table in the database managed by IBERDROLA, as it allowed, by changing a parameter in a URL (the Client code) in one of the applications of one of the companies (I-DE), unauthorized access to personal data of clients from other companies (IBERCLI and CURENERGIA), thus failing to guarantee adequate security for the personal data processed by these two companies.

Thus, IBERDROLA, as the data processor regarding the processing activities affected by the personal data breach, since it provides the service consisting of "Maintenance and support of the servers and databases that support the applications of the businesses affected by GDPR" (according to the description of the processing it carries out in the Register of Processing Activities, regarding the Activity "RET_IT_001"), as well as "Development and Maintenance of applications" (Activity "RET_IT_011"), did not adequately guarantee the total separation of the personal data of clients from different companies that are processed (stored) in the same database (in this case, in the same Table) managed by IBERDROLA.

Therefore, IBERDROLA has not complied with the obligation that, as the Data Processor, arises from the GDPR to adopt appropriate measures based on the risk posed by the processing it carries out and which is imposed by section 7.5 of the Seventh Clause of the Framework Agreement on personal data protection for the Iberdrola Group, signed on May 18, 2018, referenced in the Proven Fact Eighth and which reads as follows:

"7.5.- Obligations of the Data Processor.

e) Security Measures.

In accordance with the GDPR, apply appropriate technical and organizational measures to ensure a level of security appropriate to the risk, taking into account the state of the art, the costs of

implementation, and the nature, scope, context, and purposes of processing, as well as the risks of varying probability and severity for the rights and freedoms of individuals.

The security measures to be implemented are those indicated in Annex III of this Framework Agreement on PDP.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

74/99

For its part, it has also failed to comply with the obligations indicated in the aforementioned Annex III "Security Measures. Cybersecurity and Information Security" of the mentioned Framework Agreement, in which, among others, the following are indicated:

"The security conditions established in this Annex are applicable to the provision of services, as well as to the fulfillment of the obligations of the Data Processor in accordance with the Framework Agreement of PDP

1. (...)

3. (...)

4. (...)

(...).

IBERDROLA also alleges that the reasoning put forth by the AEPD can only be described as circular because, while it is evident that the jurisprudence has highlighted that the obligation to adopt security measures is one of means and not of results, the AEPD conducts an assessment of the alleged non-compliance by IBERDROLA with the obligation to implement security measures by reversing the reasoning that should be followed for this, indicating throughout its Proposal for Resolution that, ultimately, the measures were objectively inadequate as a consequence of the fact that an attack could indeed occur and the breach of personal data took place.

IBERDROLA therefore argues that, in this way, the AEPD seeks to evade the doctrine upheld by the Supreme Court in its ruling of February 15, 2022, referring to the insufficiency of the measures, but ultimately its reasoning is that the result is taken into consideration as a premise to consider that the means were inadequate before it occurred.

In this regard, it should be noted, first of all, that this Agency has not based its justification for the non-compliance with Article 32 of the GDPR on the result of the cyberattack, since, as derived from all the aforementioned, such non-compliance already existed prior to and independently of the attack suffered, which highlights that appropriate measures were not in place to ensure an adequate level of security in relation to the risks. Thus, it was not the result, but the fact that it was possible from an application of one of the companies to access the personal data of clients from other companies. What the incident has done is precisely to highlight the prior existence of this possibility. Therefore, that logical separation between the personal data of clients from different companies that were stored in the same Table in the database was not adequate. Likewise, it has also not demonstrated the performance of risk analyses regarding the processing activities it carries out as a data processor, so it has not been demonstrated that the implemented security measures allowed for the mitigation of unassessed risks.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

75/99

Secondly, regarding the Judgment of the Supreme Court of February 15, 2022 (cassation appeal 7359/2020), it is noted, as already indicated in the Resolution Proposal, that the aforementioned Judgment indeed states, concerning security measures in data protection, that "... the obligation that falls on the data controller and the data processor regarding the adoption of necessary measures to guarantee the security of personal data is not an obligation of result but of means, and the infallibility of the adopted measures is not required. It is only required to adopt and implement technical and

organizational measures that, in accordance with the state of technology and in relation to the nature of the processing carried out and the personal data in question, reasonably allow for the prevention of their alteration, loss, unauthorized processing, or access.” (the emphasis is ours)

However, the Judgment continues by indicating, in the specific case analyzed therein, that “... the program used for collecting customer data did not contain any security measures that would allow verifying whether the email address entered was real or fictitious and whether it actually belonged to the person whose data was being processed and who was providing consent for it. The state of technology at the time these events occurred allowed for the establishment of measures aimed at verifying the authenticity of the email address, conditioning the continuation of the process on the user receiving the contract at the provided address and only from there providing the necessary consent for its collection and processing. Measures that were not adopted in this case.

(...) Thus, at the time these events occurred, there were technical measures related to the registration process that would have prevented the personal data breach that occurred. This implies that the technical measures adopted failed to meet the security conditions as required in Article 9.1 of Law 15/1999, thus incurring the infringement provided for in Article 44.3.h) consisting of "Maintaining files, premises, programs, or equipment containing personal data without the due security conditions as determined by regulation [...]".

(...) It is stated that the technical security measures related to the software program were the responsibility of xxxx, who designed the program and was responsible for the file and the processing, and that the sanctioned company only acted on behalf of this entity by collecting data from customers who opted for financing. The truth is that the data processor - the natural or legal person who, alone or jointly with others, processes personal data on behalf of the data controller, as defined in Article 4, paragraph 8 of the Regulation, as well as Article 3.g) of Law 15/1999, and the collection of data implies processing (Article 3.c) - must also adopt the necessary technical and organizational measures to guarantee the security of personal data, as provided in Article 32.1 of Regulation (EU) 2016/679 of the Parliament and of the Council and Article 9.1 of the LOPD and is subject to the sanctioning regime established in the Law (Article 43 of Law 15/1999).

The appealing company processed customer data on behalf of the data controller, having implemented and used said program while being aware, or should have been aware, that it lacked the necessary security measures...”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

76/99

Therefore, although it can be inferred from the Judgment that the obligations established by Article 32 of the GDPR are obligations of means, it also makes it clear that if, at the time the incident occurred, there were adequate technical measures in place to prevent or mitigate its effects and they were not applied, this constitutes a breach of the aforementioned obligation imposed by the GDPR and, consequently, an infringement thereof. Moreover, these obligations pertain both to the data controller and the data processor.

It should be noted, first of all, that this judgment is issued under the regulations prior to the GDPR, in which, according to the system provided in the LOPD and the RLOPD, security measures were perfectly standardized. However, with the GDPR, there has been a shift from a system with standard and static security measures for any controller to specific security measures for each organization (adapted to its characteristics and idiosyncrasies), which consider the specific risks of the entity in question; furthermore, these measures are now dynamic, such that they are not exhausted with the implementation of the appropriate security measures at the beginning of the processing activities, but rather there must be adequate risk management that adapts to the risks that may arise.

The new regulation provided for in the GDPR significantly expands the obligations of the data controller and its scope of action and responsibility, now clearly extending to the actions carried out by its data processors, which fall within its area of responsibility. Although in this case, as previously

indicated, the processing activities carried out by IBERDROLA give rise to specific risks due to its role as a processor that it should have anticipated and mitigated, and there is no evidence that it has done so. These are risks generated by its own activity as a processor.

Secondly, the Judgment of the Supreme Court cited considers, in relation to an infringement of Article 9 of the LOPDP, that "the obligation that falls on the data controller and on the data processor regarding the adoption of necessary measures to ensure the security of personal data is not an obligation of result but of means, and the infallibility of the measures adopted is not required. It is only required to adopt and implement technical and organizational measures that, in accordance with the state of technology and in relation to the nature of the processing carried out and the personal data in question, reasonably allow for the prevention of alteration, loss, unauthorized processing, or access."

In this regard, it specifies that "It is not enough to design the necessary technical and organizational means; their correct implementation and appropriate use are also necessary, such that there will also be liability for the lack of diligence in their use, understood as reasonable diligence considering the circumstances of the case."

As has been demonstrated and argued throughout this sanctioning procedure, it is considered that appropriate security measures were not implemented to ensure adequate security relative to the risk, even if there had not been a personal data breach.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
77/99

In this regard, this Agency wishes to point out that it does not consider the obligation to implement security measures imposed by data protection regulations to be an obligation of result rather than of means. However, it is equally true that IBERDROLA did not have, prior to the incident occurring, measures that "according to the state of technology and in relation to the nature of the processing carried out and the personal data in question, reasonably allow for the prevention of their alteration, loss, processing, or unauthorized access." Therefore, while it can be inferred from the Judgment that the obligations established in Article 32 of the GDPR are obligations of means, it also makes it clear that if, at the time of the incident, there were adequate technical measures in place to prevent or mitigate its effects and they were not applied, this constitutes a breach of the aforementioned obligation imposed by the GDPR and, consequently, an infringement thereof.

In the present case, as has been pointed out, that logical separation was not adequately guaranteed because, as indicated, it was possible, by modifying a parameter of a URL in an application of one of the companies, to access personal data of clients from other companies. And this was the case prior to the attack. Therefore, liability is not being demanded solely as a consequence of a result caused by a cyberattack. It is another matter that this has been highlighted in the context of a violation of the security of personal data.

Finally, to further elaborate on all that has been indicated, it is noted that, since IBERDROLA made allegations against the accusation of having breached Article 32 of the GDPR in response to the Initiation Agreement, it is appropriate to refer to Section Four of the Legal Basis IV.

SIXTH: On the non-existence of a breach of the principle of confidentiality and integrity.

IBERDROLA again notes the absolute identity between the two infringements attributed to it to the extent that the alleged breach of Article 5.1(f) of the GDPR either results from the alleged breach of Article 32 of that Regulation or arises directly, immediately, and exclusively from this supposed second breach, that is, due to the lack of adequate security measures.

IBERDROLA points out in this regard that the AEPD has not considered the existence of any breach that does not relate to security measures, as no measure has been indicated that has failed to comply other than those of security that may be required.

In this regard, it was already indicated in the Proposal for Resolution that when Article 5.1(f) of the GDPR refers to appropriate technical or organizational measures to ensure the rights and freedoms of

data subjects within the framework of compliance management of the GDPR, it does so in the sense provided in Article 25 of the GDPR relating to privacy by design.

This provision states that,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

78/99

"Taking into account the state of the art, the cost of application, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity that the processing entails for the rights and freedoms of natural persons, the data controller shall apply, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively implement the principles of data protection, such as data minimization, and integrate the necessary safeguards into the processing, in order to comply with the requirements of this Regulation and protect the rights of the data subjects" (the underlining is ours).

It should be noted that there are multiple technical or organizational measures that are not security-related and that the data controller can implement as a means to guarantee this principle.

In this regard, IBERDROLA has not demonstrated that it has complied with the provisions of this article, as it has not been proven that, in accordance with the risks of varying probability and severity that the processing entails for the rights and freedoms of natural persons, it has applied appropriate technical and organizational measures such as, for example, pseudonymization, designed and aimed at effectively implementing the principles of data protection, among which is the principle of confidentiality.

Therefore, the GDPR requires the applicability of data protection from the design stage and the need to manage both the risks to the rights and freedoms of individuals and the impact on those rights and freedoms that a data breach could have, especially in web environments, as they can affect a large volume of the population.

As stated in the guidelines for processing that involves the communication of data between public administrations of this Agency, whose reasoning is extrapolatable to large organizations that handle a significant amount of data, there are always risks related to personal data breaches. However, these will be particularly considerable in the processing of personal data carried out by large public and private organizations that are serving a large portion of the citizens, and even more so if they are interconnected. It is very important to consider that the risk posed by personal data breaches in such processing does not depend so much on whether sensitive and/or specially protected categories of data are being processed, but rather on the consequences for fundamental rights that may arise from a compromise of the information.

To estimate the impact that a personal data breach could have, one must consider the consequences that would arise from its materialization. One way to do this is, before a breach occurs, to consider the possible scenarios of materialization of a compromise of personal data, determine their consequences, and evaluate how it affects the rights and freedoms of the data subjects, especially if it involves irreversible consequences for their fundamental rights.

Regarding the appropriate measures in relation to the level of risks to rights and freedoms, Article 24.1 of the GDPR establishes that the measures to be adopted in a...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

79/99

treatment to ensure and demonstrate compliance with the Regulation

must take into account the scope, context, and purposes of the treatment, particularly considering the extent of affected subjects and the risk it poses to fundamental rights, and not just the type of data.

The aforementioned Guidelines indicate that "the technical and organizational measures adopted must

be specifically aimed at minimizing the identified risks to the rights and freedoms of potential personal data breaches. This implies that the data controller must assess the risks that may arise, design measures aimed at minimizing their probability and impact, and determine to what extent such measures are appropriately managing the specific risks in a dynamic process.”

It is also added that “appropriate measures must be selected and implemented from the design of the treatments so that all risk contexts for rights and freedoms are considered. It should be noted that some measures will be more effective in preventing or mitigating the direct impact on individuals, while other measures will primarily address the social impact on fundamental rights. A high level of data protection by default must be applied...”

It is undisputed that a personal data breach may occur; therefore, within the risk management of a particular organization, precisely because a breach may occur, this scenario must be evaluated as an integral part of risk management for the purposes of (i) adopting all types of appropriate technical and organizational measures to prevent its materialization and (ii) determining post hoc measures to minimize damages. On this particular issue, the aforementioned Guidelines explain that “in light of the possible scenarios of materialization of different types of breaches, at least the following questions must be addressed from the design of the treatment and prior to its implementation:

- What personal and social impact could a personal data breach have if it materializes?
- What data protection measures should be implemented a priori to minimize the personal and social impact that a materialized breach could produce?
- What response measures must be planned and executed post hoc, once the breach has occurred, to minimize the personal and social impact?”

Therefore, its management cannot be based exclusively on the realm of cybersecurity, but must encompass all areas in which the treatment is developed, since otherwise, risk management would not be complete and, therefore, would be futile. For this, it is essential to adopt specific measures for data protection from the design and by default, as well as measures for effective management of the consequences of the breach aimed at protecting the fundamental rights of individuals.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

80/99

As noted, there are multiple technical or organizational measures that are not security-related and that the data controller can implement as a means to ensure the principle of confidentiality.

In this regard, IBERDROLA has not demonstrated compliance with the provisions of the GDPR, as it has not been proven that, in accordance with all of the above, it has evaluated those risks and applied appropriate technical and organizational measures aimed at effectively implementing the principles of data protection, including measures aimed at ensuring the principle of confidentiality. Furthermore, it should be emphasized that in this case, the breach of the principle of confidentiality has materialized. Moreover, aside from the above, even in the risk analysis to adopt the security measures of Article 32, it has not been indicated what measures should be adopted to mitigate that "medium" risk indicated as affecting the processing activity impacted by the breach, as will be indicated later in a more extensive and detailed manner in the response to the Fourth Allegation of this Legal Basis.

Therefore, in the case examined, as evidenced by the proven facts, there is a clear loss of confidentiality since unauthorized access by a third party to the personal data processed by IBERCLI and CURENERGÍA has occurred, for which IBERDROLA acts as the data processor. This does not imply objective liability, as IBERDROLA was not diligent in not ensuring adequate security through the application of appropriate technical and organizational measures, not only of a security nature but of all types.

Regarding what IBERDROLA has stated concerning the fact that this AEPD has not demonstrated in any way the materialization of the risk posed by the loss of confidentiality for the affected individuals, that no client of IBERCLI or CURENERGÍA has seen their rights affected as a result of the security breach that occurred, which it understands does not allow for the consideration of an infringement of a principle and the imposition of a fine of two million euros based on mere potentiality or the

consideration that a high risk of fraud could occur, which has not been demonstrated in any way. In response to this, and as already indicated in the Proposal for Resolution, what is attributed to IBERDROLA is the violation of the principle of confidentiality, as it is established that, after suffering a cyberattack through the GEA web application, there was unauthorized access and extraction by a third party of the personal data processed by CURENERGÍA and IBERCLI, which resulted in the loss of confidentiality and control over numerous personal data (...) and affected 1,515,000 clients of IBERCLI and 92,550 of CURENERGÍA. Therefore, the risk did materialize, consisting of the loss of confidentiality and the loss of control over the data.

What is guaranteed is confidentiality in order to avoid the serious harm that its breach can cause, as it poses a high risk for the affected individuals—in the event of a breach of confidentiality—of fraudulent use of the data: identity theft for online contracting, phishing, financial fraud, etc. The loss of confidentiality has already occurred in this case due to the access and the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

81/99

exfiltration, whereby there is no longer a “probability” of risk, but rather a realization of this risk causing damage by itself. This implies a breach of the duty to guarantee the confidentiality of personal data, as indicated, Article 5.1.f) states that personal data must be processed in such a way as to ensure an adequate level of security, including protection against unauthorized or unlawful processing.

Furthermore, regarding the assertion that none of its clients have been affected in any of their rights as a result of the security breach, IBERDROLA overlooks that the very loss of confidentiality suffered implies that the core of the fundamental right to data protection is affected, which is none other than having control over personal data.

Regarding the high risk indicated that such data, in the hands of cybercriminal(s), could be used fraudulently, this was mentioned to express what the loss of confidentiality entails, but it is not necessary in any way for the infringement of Article 5.1.f) to understand that such risks of fraudulent use materialize, because what has materialized with the breach is the loss of confidentiality of the personal data processed by IBERDROLA, which is what is exclusively attributed to it.

For the reasons stated, the allegation is dismissed.

SEVENTH: On the violation of the principle of proportionality to the detriment of IBERDROLA's rights IBERDROLA draws attention to the fact that the same aggravating circumstances have been applied in relation to the two infringements attributed, which it understands evidences the extent of the connection between both in total, proceeding with the application of what was invoked in Allegations Two and Three (violation of the non bis in idem principle and existence of medial concurrence).

In this regard, it has already been indicated to it, concerning the application of identical aggravating factors in both infringements, that the circumstances provided for in Article 83.2 of the GDPR and those set forth in Article 76.2 of the LOPDGDD are the only ones that can be applied by the AEPD for any infringement.

What is decisive in this case is not that they coincide in their use, but rather the reasoning established for their consideration.

Additionally, IBERDROLA alleges the improper application of Article 83.2.a) of the GDPR, drawing attention to the fact that it has been considered appropriate to aggravate the imposed sanction due to the occurrence of a loss of confidentiality of personal data, both in relation to Article 32 and Article 5.1.f).

Thus, IBERDROLA argues that, in relation to the infringement of Article 32, according to the traditional concept of security in systems, it aims to guarantee the integrity, confidentiality, and availability of information, so that if the AEPD considers that the occurrence of a breach of confidentiality...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

The breach of confidentiality would aggravate the conduct consisting of the alleged absence of such security measures; any accusation for the alleged infringement of Article 32 will be aggravated by the AEPD, which would lead to the inclusion in the catalogue of infringements of a sort of aggravated type by its very nature, which, however, is not reflected in the GDPR or in the LOPDGDD.

In this regard, it should be noted, contrary to the argument presented, that the violation of confidentiality is not necessary or essential for the commission of the infringement of Article 32, since, as already indicated previously, Article 32 can be violated due to the absence of appropriate security measures or due to inefficiency in their use or implementation, without necessarily having occurred a breach of personal data. It is a different matter that the infringement of Article 32 is evidenced as a consequence of the materialization of a violation of the security of personal data which, by its very definition, involves “any breach of security that leads to the accidental or unlawful destruction, loss or alteration of personal data transmitted, stored or otherwise processed, or to the unauthorized communication or access to such data” (paragraph 12 of Article 4 of the GDPR).

Therefore, in the present case, the logical separation existing in the database was inadequate as it allowed, by modifying a parameter in an application of one of the companies, access to personal data of clients of other companies for which there is no authorization for such access.

This demonstrates that IBERDROLA was not applying appropriate measures to ensure a level of security adequate to the risk of its processing, which in itself constitutes a violation of Article 32. If, in addition, such deficiencies have allowed or facilitated, as is the case, that a breach of personal data has occurred (in this case, a breach of confidentiality), there is no obstacle to considering such violation as an aggravating circumstance under Article 83.2.a), which allows taking into account the “nature, gravity and duration of the infringement, considering the nature, scope or purpose of the processing operation in question as well as the number of affected parties and the level of damage and harm suffered” (the emphasis is ours).

Regarding the application of the aggravating factor of Article 83.2.a) for the violation of Article 5.1.f), while it is true that the violation of confidentiality is not appropriate as a circumstance to be considered for aggravating the infringement since it is subsumed in the very infringing type, it is also true that this provision, Article 83.2.a) of the GDPR, has been applied as an aggravating factor taking into account, moreover, the number of affected parties, which is very numerous, amounting to more than one million people (1,607,550), as well as the fact that numerous personal data were stolen (...), so it is appropriate to continue considering these circumstances as aggravating factors, thus Article 83.2.a) of the GDPR remains applicable.

Regarding IBERDROLA's understanding that in relation to this aggravating factor it is intended to take into account certain alleged damages and losses suffered, which have not been substantiated by the AEPD, it is clarified that what is taken into account in this aggravating factor is the damage and risk that the loss of confidentiality itself entails, which involves a total loss of control over one's own personal data and the high risk.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

which entails that they are used fraudulently, as they have been stolen by a cybercriminal.

On the other hand, IBERDROLA argues that the aggravating factor of Article 83.2.b) of the GDPR related to the existence of negligence cannot be applied to it since, in the Judgment of the European Court of Justice, dated December 5, 2023 (case C-807/21), it is stated that:

“75 Consequently, it must be declared that Article 83 of the GDPR does not allow for the imposition of an administrative fine for an infringement covered in its paragraphs 4 to 6 without demonstrating that such infringement was committed intentionally or negligently by the data controller and that, therefore, culpability in the commission of the infringement constitutes a requirement for the imposition of the fine.”

From this, IBERDROLA deduces that if such intent or negligence is necessary for the infringement to

be considered committed, it is difficult to consider that the most serious form of culpability required can act as an aggravating circumstance, and even less so based on a subjective criterion, such as the volume of IBERDROLA.

In contrast, it should be noted that it is one thing that, in order to attribute an administrative infringement, the existence of intent or negligence is necessary, and another that the existence of a particularly highlighted negligence, due to the circumstances of the case, cannot be used as an aggravating factor. The opposite would be contrary to Article 83.2.b) itself, which establishes that "When deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

b) the intent or negligence in the infringement."

Thus, in any infringement of data protection regulations, the existence of intent or negligence must be present. This applies to both natural persons and legal entities as data controllers, whether it is a small company with little involvement in the processing of personal data, or a large company, a multinational, etc., with continuous and large-scale processing of personal data, for example.

Therefore, once it is determined that, as a premise, this subjective culpability element is present, this does not prevent the consideration of the aggravating factor of intent or negligence indicated by considering that, in accordance with the specific circumstances of the case, a different degree of intent or negligence in the actions of the infringing party may be considered. Thus, in accordance with the Guidelines 04/2022 of the European Data Protection Board on the calculation of administrative fines under the GDPR, in its version 2.1, adopted on May 24, 2023, it states the following:

"4.2.2 — Intentional or negligent nature of the infringement

55. In its previous guidelines, the EDPB stated that 'in general, intent includes both knowledge and will in relation to the characteristics of...'

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

84/99

a crime, while "unintentional" means that there was no intention to cause the infringement, although the responsible party/data controller failed to fulfill the duty of care required by law.

Example 4 — Illustrations of intent and negligence (from WP 253)

"The circumstances indicative of intentional violations may include illicit processing explicitly authorized by the senior management of the data controller, or despite the advice of the data protection officer, or in violation of existing policies, for example, obtaining and processing data about employees of a competitor with the intention of discrediting that competitor in the market. Other examples here may include:

- the modification of personal data to give a misleading (positive) impression of whether objectives have been met; we have seen this in the context of objectives for hospital waiting times

- the trading of personal data for commercial purposes, i.e., the sale of data as 'opted-in' without checking or ignoring the opinions of the data subjects on how their data should be used

Other circumstances, such as the failure to read and comply with existing policies, human error, the lack of verification of personal data in published information, the failure to implement technical updates in a timely manner, and the lack of adoption of policies (rather than simply the lack of enforcement) may be indicative of negligence";

56. The intentional or negligent nature of the infringement [Article 83, paragraph 2, letter b), of the GDPR] must be assessed taking into account the objective elements of conduct derived from the facts of the case. The EDPB highlighted that it is generally accepted that intentional violations,

"demonstrating contempt for the provisions of the law, are more serious than unintentional ones." In the case of intentional infringement, it is likely that the supervisory authority will give more weight to this factor. Depending on the circumstances of the case, the supervisory authority may also give weight to the degree of negligence. In the best case, negligence could be considered neutral." (the emphasis is ours)

In the present case, the aggravating factor of negligence is evident as IBERDROLA manages a

database in which personal data of customers from different companies is stored, needing to ensure adequate security for such processing and absolute separation at all times. However, there was an inadequate configuration that did not guarantee appropriate logical separation and allowed unauthorized access to personal data of other companies from an application of one of the companies. Furthermore, in relation to the infringement of Article 5.1(f) of the GDPR, negligence shown by IBERDROLA is also evident as, as noted, due to its subjective circumstances and the large number of personal data of numerous customers of the companies for which it acts as the data processor (21 million customers of I-DE; 8 million of IBERCLI; 3

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
85/99

millions of CURENERGÍA), a higher degree of professionalism and diligence is required in the duty to guarantee the confidentiality of the personal data of those companies.

Regarding the consideration of IBERDROLA's size as an aggravating factor, it should be noted that the same level of diligence cannot be required of a company like IBERDROLA as that which is required of a natural person or a small business, for example. This implies that a higher level of diligence is demanded because the level of professionalism is greater.

It is worth recalling, in this regard, the Judgment of the National Court of 17/10/2007 (rec. 63/2006), which regarding entities whose activity involves the continuous processing of customer data, indicates that "...the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the offender does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard."

Finally, contrary to what IBERDROLA has stated, the consideration of this aggravating factor of negligence has never meant that the maximum limit of the sanction to be imposed has increased, since the maximum limits are established in sections 4 and 5 of Article 83 of the GDPR, which allow for the imposition of a sanction of 10,000,000 euros or 2% of the total annual global turnover and 20,000,000 euros or 4% of the total annual global turnover, respectively. Therefore, at no time has the maximum amount of the sanction that could be imposed as a consequence of the application of the aggravating factors been established, as IBERDROLA indicates.

Regarding the aggravating circumstance set forth in Article 76.2.b of the LOPDGDD, IBERDROLA states that its conduct is being aggravated merely by the fact of belonging to a specific sector of activity. In this respect, it is noted that this provision does not take into account the specific activity to which IBERDROLA is dedicated (electric sector), but rather its connection with the processing of personal data, as it carries out massive and large-scale processing (at least 21 million customers of I-DE; 8 million of IBERCLI; 3 million of CURENERGÍA) and continuously.

In this sense, the Spanish legislator has considered including in Article 76 of the LOPDGDD that: "2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

(...)

b) The connection of the offender's activity with the processing of personal data."

This Agency simply takes that circumstance, provided by the legislator, into account when deciding on the imposition of the administrative fine.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
86/99

Finally, IBERDROLA alleges a breach of the principle of equal treatment when considering the

precedents of this Agency. It points out the procedure PS/000179/2020, in which it indicates that a lesser sanction was imposed despite understanding that the circumstances were more serious. Moreover, in that file, no sanction was imposed for the violation of Article 5.1.f) of the GDPR, despite the manifest existence of a breach of data confidentiality. Therefore, the AEPD has modified its criteria, as it now converts what was previously considered a violation of Article 32 of the GDPR into two violations by now referring to Article 5.1.f) of the GDPR, and significantly multiplying the total amount of the infringement, which constitutes a flagrant breach of the principles of equality, legal certainty, and public faith. It also states that this goes against the doctrine of acts of one's own. In response to this, as already indicated in the Proposal for Resolution, the circumstances and facts of procedure PS/000179/2020 are neither the same nor comparable, and there can be no equality in illegality; thus, it is not appropriate to attempt to equate sanctions for different facts and circumstances. Therefore, it is necessary to refer to the response given to this same allegation, which is fully transcribed in Section Six of the Legal Basis IV of this Resolution.

Regarding what IBERDROLA claims concerning the breach of the principle of equality in that only a sanction was imposed for a violation of Article 32 in PS/000179/2020 and that a violation of Article 5.1.f) of the GDPR was not considered, despite the existence of a breach of confidentiality, and that this also goes against the doctrine of acts of one's own, it is noted that IBERDROLA has only selected and brought up this file to defend an alleged unequal treatment, while it overlooks the numerous sanctioning procedures existing prior to the present one, in which, after a breach of confidentiality occurred, sanctions were imposed for the infringement of both provisions. By way of example and without being exhaustive, as there are more, the following should be indicated: PS/00444/2021, PS/00420/2021, PS/00528/2021, PS/00099/2022, PS/00113/2022, PS/00164/2022, PS/00419/2022, PS/00168/2022.

Finally, regarding procedure PS/0002/2023, in which two sanctions were also imposed for violating both Article 32 and Article 5.1.f) of the GDPR, and which also refers to a company in the electricity sector, IBERDROLA brings it up for comparison, because there, the total amount of the two sanctions for these two violations exceeds by only one million euros the amounts imposed on IBERDROLA, despite the fact that there were affected parties. It is again noted that the facts and circumstances are different and that, therefore, a different (in this case, higher) fine was imposed, in addition to other fines for other distinct violations that were considered.

In this regard, it is again recalled that, in the field of data protection, the technical and organizational security measures to be adopted by the data controllers and processors, as well as other obligations required by the GDPR, must be appropriate in relation to the specific risks posed by the specific treatments carried out by each controller. Therefore, when analyzing the diligence of each party in complying with the regulations, it must be taken into account that...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

87/99

the circumstances of each case, taking into account the nature, scope, context, and purposes of each processing, there are no identical cases. In this regard, it should be noted that Article 83, in its paragraph 2, establishes that “Administrative fines shall be imposed, depending on the circumstances of each individual case...” (the underline is ours). It should not be overlooked that in that procedure a fine exceeding one million euros was imposed in relation to the present case. Therefore, it is necessary to consider the circumstances of each individual case, as there are no two identical files and, consequently, no identical outcomes.

As a general and final consideration, it should be pointed out that none of the sanctions applied violate the principle of proportionality. Thus, it should be recalled that Articles 83.4 and 83.5 of the GDPR, where the infringement of Article 32 and that of Article 5.1.f) are respectively defined, establish limits on the amounts of fines that can be imposed, which are far removed from those that have ultimately been established.

Thus, Article 83.4 of the aforementioned Regulation establishes that they shall be sanctioned, in

accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount. In this regard, according to the entity Axesor, the turnover for 2022 of IBERDROLA was ***CANTIDAD.2 euros, which would have allowed for a sanction of up to ***CANTIDAD.3 euros for the infringement of Article 32.

On the other hand, Article 83.5 of the GDPR establishes that they shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount. In this regard, according to the indicated turnover, it would have allowed for a sanction of up to ***CANTIDAD.4 euros for the infringement of Article 5.1.f).

Therefore, taking into account the above, as well as IBERDROLA's negligence in managing a database in which personal data of millions of customers from different companies are stored, which obliges it to ensure adequate security for such processing at all times and an absolute separation, there was, however, an inadequate configuration that did not guarantee appropriate logical separation and allowed unauthorized access to the personal data of other companies from an application of one of the companies. Likewise, considering the high number of affected individuals whose personal data was exfiltrated by a cybercriminal, which represents an irretrievable loss of control over personal data, with the risks that this entails, it cannot be said that the sanctions ultimately imposed violate the principle of proportionality, taking into account that "Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 are in each individual case effective, proportionate, and dissuasive" (the underline is ours).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
88/99

For the reasons stated, the allegation is dismissed.

VI

Integrity and Confidentiality

Article 5.1.f) "Principles relating to processing" of the GDPR establishes:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, by means of the application of appropriate technical or organizational measures ('integrity and confidentiality')."

The principle of integrity and confidentiality of data requires a guarantee of security in the application of technical or organizational measures that prevent the alteration of personal data, its loss, unauthorized or unlawful processing or access. The existence of this fundamental right is not possible if confidentiality, integrity, and availability are not guaranteed.

Hence, the integrity and confidentiality of personal data are considered essential to prevent data subjects from suffering negative effects. Therefore, they must be processed in a manner that ensures adequate integrity and confidentiality of personal data, especially to prevent unauthorized access, processing, or use of such data.

Ultimately, both the data controller and the processor have the obligation to integrate the necessary guarantees in the processing, with the aim of, under the principle of proactive responsibility, complying with and being able to demonstrate compliance, while respecting the fundamental right to data protection.

In this regard, it should be noted that the confidentiality of personal data is regulated in Article 5 of the GDPR and is therefore one of the principles relating to processing. The principles relating to processing are, on one hand, the starting point and the closing clause of the legal framework for data protection, constituting true guiding rules of the system with intense expansive force; on the other

hand, having a high level of specificity, they are mandatory norms that can be infringed. Article 5.1.f) of the GDPR establishes a clear obligation of compliance consisting of preventing unauthorized or unlawful processing by implementing appropriate security measures. Therefore, one must be in a position to guarantee the confidentiality of personal data to prevent a third party from accessing data that does not belong to them, as it is mandatory to process personal data in accordance with the GDPR and LOPDGDD. For this reason, it is an activity where the diligence provided by

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
89/99

Responsibility and the role of data processors are fundamental to prevent such unauthorized access. In this case, the principle of confidentiality has been violated as it is recorded that following a cyber attack against a web application of the company I-DE (GEA), in addition to an unlawful access to personal data processed by it, there was also an illegitimate access to personal data - and the extraction of the same - from two different companies and processed by IBERDROLA in its capacity as a data processor.

In this regard, it should be noted that IBERDROLA, as the data processor for IBERCLI and CURENERGÍA, processes personal data on their behalf; specifically, in this case, IBERDROLA manages and administers the systems and the database where the personal data of these two companies are stored. However, the attack suffered by another company in the Group (which also hosts its data in the same location) has led to the exfiltration of personal data contained in the aforementioned database and belonging to clients of other entities in the Group, thus failing to guarantee the confidentiality of the personal data of both parties.

This has resulted in the loss of confidentiality and control over numerous personal data (...) affecting 1,515,000,000 clients of IBERCLI and 92,550 clients of CURENERGÍA. This constitutes a breach of the duty to ensure the confidentiality of personal data, as indicated, Article 5.1(f) states that personal data must be processed in such a way as to ensure an adequate level of security, including protection against unauthorized or unlawful processing.

Therefore, the risk of loss of confidentiality has materialized, having been usurped by a cybercriminal, which means that they can be used for unknown purposes (sold, communicated, published, etc.), all without the consent of their owners, resulting in a total and absolute loss of control over them. Furthermore, it also poses a very high risk of fraudulent use (identity theft, fraud, financial losses, etc.) or that they may serve any other purpose that, under certain circumstances, constitutes a threat to their owners. It should also be noted that most of the leaked personal data are data that cannot be modified or changed (name, surname, ID number, address...)

This loss of control over one's own personal data translates into a violation of the fundamental right to data protection recognized in Article 18 of the Spanish Constitution, as indicated by the Constitutional Court (Judgment 292/2000, of November 30, 2000) "the fundamental right to data protection seeks to guarantee individuals a power of control over their personal data, over its use and destination, in order to prevent its illicit and harmful trafficking to the dignity and rights of the affected party (...) The right to data protection guarantees individuals a power of disposition over that data."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

90/99

In light of all the above and in accordance with the available evidence, it is considered that the known facts constitute an infringement attributable to IBERDROLA for violating Article 5.1(f) of the GDPR.

VII

Classification of the infringement of Article 5.1(f) of the GDPR

The aforementioned infringement of Article 5.1(f) of the GDPR constitutes the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the limitation period, Article 72 "Infringements considered very serious" of the LOPDGDD indicates:

"1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following are considered very serious and shall prescribe after three years: infringements that constitute a substantial violation of the articles mentioned therein, particularly the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

VIII

Sanction for the infringement of Article 5.1(f) of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the available evidence, it is appropriate to grade the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

- Article 83.2(a) GDPR: Nature, gravity, and duration of the infringement.
- Number of affected parties: the number of affected individuals is very large, as it amounts to more than one and a half million people (1,607,550).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

91/99

- Level of damages suffered: High. Numerous personal data (...) and a very considerable number of clients (1,607,550) were stolen by a cybercriminal, thus losing all control over them, which poses a high risk of fraudulent use (identity theft, fraud, financial losses, etc.), thereby undermining the fundamental right to the protection of personal data which, as indicated by the Constitutional Court in the previously mentioned ruling, aims to guarantee individuals a power of control and disposition over their personal data, its use and destination, in order to prevent its illicit trafficking and harm to the dignity and rights of the affected party.

- Article 83.2.b) GDPR. Intent or negligence in the infringement: There is evidence of negligence in the compliance and observance of technical and organizational measures to ensure the necessary security for the protection of personal data, specifically to guarantee the confidentiality of such data. In this regard, it should be noted that IBERDROLA is a large company that, as a data processor, carries out large-scale processing, affecting numerous individuals (from the statements made by the three companies affected by the breach, it processes data of at least 21 million people), which requires a higher level of diligence and adequate security measures to ensure the confidentiality of the personal data it processes.

It is worth recalling, in this sense, the ruling of the National Court of 17/10/2007 (rec. 63/2006), which regarding entities whose activity involves the continuous processing of customer data, indicates that "...the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the offender does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be particularly weighed,

and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard."

As mitigating factors:

- Article 83.2.c) GDPR. Measures taken by the controller or processor to mitigate the damages suffered by the affected parties: Positive. As it was she who, upon detecting performance and availability issues on the website, confirmed that it was a breach and proceeded to block the attacker's IP and to notify I-DE of the breach, which may have prevented a much more severe impact. She also managed the breach jointly with I-DE.

Furthermore, it is considered appropriate to adjust the sanction to be imposed according to the following criteria established in section 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As aggravating factors:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

92/99

- Article 76.2.b) LOPDGDD. Linkage of the infringer's activity with the processing of personal data: The development of the business activity carried out by IBERDROLA involves continuous and large-scale processing of personal data, as it processes data as a processor for at least 21 million people.

Therefore, it is a large company accustomed to the processing of personal data.

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available, taking into account the circumstances of the case and the criteria established in Article 83.2 of the GDPR regarding the infringement committed by violating the provisions of Article 5.1.f) of the GDPR, it allows for the imposition of a fine of €2,000,000 (two million euros).

IX

Article 32 of the GDPR

Article 32 "Security of processing" of the GDPR establishes:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and...

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
93/99

have access to personal data may only process such data following the instructions of the controller, unless required to do so by Union or Member State law.”

Article 32 does not establish static security measures; it is up to controllers and processors to determine the necessary security measures to ensure the confidentiality, integrity, and availability of personal data. Therefore, the same data processing may involve different security measures depending on the specific circumstances in which such data processing takes place.

In line with these provisions, Recital 75 of the GDPR states: The risks to the rights and freedoms of natural persons, of varying severity and probability, may arise from data processing that could cause physical, material, or immaterial harm, particularly in cases where processing could lead to issues of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; in cases where data subjects are deprived of their rights and freedoms or prevented from exercising control over their personal data; in cases where the personal data processed reveal ethnic or racial origin, political opinions, religion or philosophical beliefs, trade union membership, and the processing of genetic data, data concerning health, or data about sexual life, or criminal convictions and related security measures; in cases where personal aspects are evaluated, in particular the analysis or prediction of aspects related to work performance, economic situation, health, preferences or personal interests, reliability or behavior, situation or movements, in order to create or use personal profiles; in cases where personal data of vulnerable individuals, particularly children, are processed; or in cases where the processing involves a large amount of personal data and affects a large number of data subjects. (the underlining is ours)

Furthermore, Recital 83 of the GDPR states: In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or processor must assess the inherent risks of the processing and implement measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that must be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be considered, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, particularly susceptible to causing physical, material, or immaterial harm. (the underlining is ours)

In this regard, it should be emphasized that Article 28.3.c) of the GDPR assigns to the processor the obligation to take all necessary measures in accordance with Article 32.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
94/99

The security of data requires the application of appropriate technical or organizational measures in the processing of personal data to protect such data against unauthorized or unlawful access, use, modification, dissemination, loss, destruction, or accidental damage. In this sense, security measures are key to guaranteeing the fundamental right to data protection. The existence of the fundamental right to the protection of personal data is not possible if confidentiality, integrity, and availability of such data cannot be guaranteed. It should not be forgotten that, in accordance with Article 32.1 of the cited GDPR, the technical and organizational measures to be applied to ensure an adequate level of security relative to the risk must take into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, as well as the variable likelihood and severity of risks to the rights and freedoms of natural persons.

Therefore, IBERDROLA, when assessing risks and determining the appropriate technical and

organizational measures to ensure an adequate level of security relative to the risk for the rights and freedoms of natural persons in the data processing it carries out as a data processor, is obliged to consider the specific activity that constitutes its business, which involves processing personal data continuously and on a large scale (numerous data to be collected, processed, stored...); the type of data processed: identifying, contact, those related to the supply and consumption of electricity, bank accounts, etc.; the context: existence of web applications on the internet, that is, in a non-isolated environment, which entails risks arising from the very interconnectivity that the network implies, which must be addressed in a specialized manner; existence of a common database shared by several companies with requirements for separation (physical or logical).

Therefore, due to the activity in which it is engaged, IBERDROLA is obliged to carry out a highly specialized risk analysis and implement appropriate technical and organizational measures to ensure an adequate level of security relative to the risk of its activity for the rights and freedoms of individuals. In this case, as previously noted, due to the cyberattack suffered by a web application of one of the companies in the group, there was, in addition to unauthorized access to the personal data processed by that company, unauthorized access to personal data of clients from two other different companies and an unlawful exfiltration of the same, as the logical separation existing in the database where personal data of various companies in the Group are housed and managed by IBERDROLA was circumvented or breached.

(...).

(...).

(...).

(...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

95/99

(...).

All of the above demonstrates that IBERDROLA did not have the appropriate technical and organizational measures in place to ensure total separation between the personal data of the different companies for which it acts as a data processor and that, therefore, the security incident that occurred in this case, affecting CURENERGÍA and IBERCLI, took place, meaning that it did not apply appropriate technical and organizational measures to ensure an adequate level of security relative to the risk of its personal data processing.

Therefore, in accordance with the available evidence, it is considered that the known facts constitute an infringement attributable to IBERDROLA for violation of Article 32 of the GDPR.

X

Classification of the infringement of Article 32 of the GDPR

The aforementioned infringement of Article 32 of the GDPR constitutes the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to 2% of the total annual global turnover of the preceding financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements," establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the limitation period, Article 73 "Infringements considered serious" of the LOPDGDD indicates:

"Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall prescribe after two years: infringements that constitute a substantial

violation of the articles mentioned therein and, in particular, the following:

(...)

f) The failure to adopt those technical and organizational measures that are appropriate to ensure an adequate level of security relative to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.

XI

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

96/99

Sanction for the violation of Article 32 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available, it is appropriate to assess the sanction to be imposed, according to the following criteria established by Article 83.2 of the GDPR:

As aggravating factors:

- Article 83.2.a) GDPR: Nature, severity, and duration of the infringement.
- It is considered that the nature of the infringement is serious as it has resulted in a loss of confidentiality and, therefore, of irretrievable control and disposition over personal data.
- Number of affected parties: The number of affected individuals is very high, as it amounts to over one and a half million people (1,607,550).
- Level of damages suffered: High. Numerous personal data were stolen (...) and from a very considerable number of clients (1,607,550), thus losing all control over them, which poses a high risk of fraudulent use (identity theft, fraud, financial losses, etc.), thereby undermining the fundamental right to the protection of personal data which, as indicated by the Constitutional Court in the previously mentioned ruling, aims to guarantee individuals control and disposition over their personal data, regarding its use and destination, with the purpose of preventing its illicit and harmful trafficking to the dignity and rights of the affected party.
- Article 83.2.b) GDPR. There is evidence of negligence on the part of IBERDROLA in complying with and observing the technical and organizational measures necessary to ensure the security required for the protection of personal data, specifically to guarantee the confidentiality of such data. In this regard, it should be noted that IBERDROLA is a large company that, as a processor, carries out large-scale processing, affecting numerous individuals (from the declarations made by the three companies affected by the breach, it processes data of at least 21 million people), for which a higher level of diligence and appropriate security measures are required to ensure the confidentiality of the personal data it processes.

It is worth recalling, in this sense, the ruling of the National Court of 17/10/2007 (rec. 63/2006), which regarding entities whose activity involves the continuous processing of customer data, indicates that "...the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the offender does not behave with the required diligence. And in assessing the degree of diligence, the professionalism of the subject must be particularly weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted on the rigor and exquisite care to comply with the legal provisions in this regard."

As mitigating factors:

- Article 83.2.c) GDPR. Measures taken by the controller or processor to mitigate the damages suffered by the affected parties: Positive. As it was IBERDROLA that, upon detecting performance and availability issues on the website, confirmed that it was a breach and proceeded to block the attacker's IP and to notify I-DE of the breach, which may have prevented a much more serious impact. It also managed the breach jointly with I-DE.

Furthermore, it is considered appropriate to assess the sanction to be imposed according to the following criteria established in section 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As aggravating factors:

- Article 76.2.b) LOPDGDD. Linkage of the infringer's activity with the processing of personal data: The development of the business activity carried out by IBERDROLA involves continuous and large-scale processing of personal data. Therefore, it is a large company accustomed to processing personal data. The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 32 of the GDPR, allows for the imposition of a sanction of €1,000,000 (one million euros).

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established, the Director of the Spanish Data Protection Agency RESOLVES:

FIRST: TO IMPOSE on IBERDROLA, S.A., with NIF A48010615, for an infringement of Article 5.1.f) of the GDPR, classified under Article 83.5 of the GDPR, an administrative fine of €2,000,000 (two million euros).

SECOND: TO IMPOSE on IBERDROLA, S.A., with NIF A48010615, for an infringement of Article 32 of the GDPR, classified under Article 83.5 of the GDPR, a fine of €1,000,000 (one million euros).

THIRD: TO NOTIFY this resolution to IBERDROLA, S.A.

FOURTH: This resolution will be enforceable once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has expired without the interested party having exercised this right.

The sanctioned party is warned that they must comply with the imposed sanction once this resolution becomes enforceable, in accordance with the provisions of Article 98.1.b)

98/99

of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account No. IBAN: ES00-0000-0000-0000-0000, opened in the name of the Spanish Agency for Data Protection at the bank CAIXABANK, S.A.

Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once it is executive, if the date of executive status falls between the 1st and the 15th of each month, inclusive, the deadline for making the voluntary payment will be until the 20th of the following month or the next business day thereafter, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day thereafter.

In accordance with the provisions of Article 76.4 of the LOPDGDD and given that the amount of the imposed sanction exceeds one million euros, the information identifying the offender, the infringement committed, and the amount of the sanction will be published in the Official State Gazette.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency

[<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

938-16012024

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

99/99

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es